

IGOR COSTA D'OLIVEIRA
PAULO HENRIQUE DINIZ FERNANDES

Negação plausível em sequestros relâmpagos:
implementação do modo pânico em aplicativos
bancários.

IGOR COSTA D'OLIVEIRA
PAULO HENRIQUE DINIZ FERNANDES

**Negação plausível em sequestros relâmpagos:
implementação do modo pânico em aplicativos
bancários.**

Trabalho apresentado à Escola Politécnica da Universidade de São Paulo para obtenção do Título de Engenheiro da computação.

São Paulo
2024

IGOR COSTA D'OLIVEIRA
PAULO HENRIQUE DINIZ FERNANDES

**Negação plausível em sequestros relâmpagos:
implementação do modo pânico em aplicativos
bancários.**

Versão Final

Trabalho apresentado à Escola Politécnica da Universidade de São Paulo para obtenção do Título de Engenheiro da computação.

Orientador:

Prof. Dr. Marcos Antônio Simplício
Júnior

Co-orientador:

Profa. Dra. Yeda Regina Venturini

São Paulo
2024

RESUMO

Este projeto de conclusão de curso foi desenvolvido na Escola Politécnica da Universidade de São Paulo (Poli-USP). A obra visa à implementação da negação plausível em sequestros relâmpagos para criar o modo pânico em aplicativos bancários e mitigar os danos causados por esse tipo de crime.

O avanço do sistema PIX no Brasil facilitou a transferência de recursos financeiros entre indivíduos, mas também intensificou os casos de sequestros relâmpagos. O Ministério Público e a Febraban destacaram a necessidade urgente de novas medidas para conter essa tendência. O objetivo principal é proteger os usuários contra acesso indevido a informações financeiras durante situações de emergência, como tentativas de acesso sob coação. O sistema proposto utiliza senhas alternativas e altera temporariamente os dados financeiros visíveis para mitigar riscos e aumentar a segurança bancária.

Implementado nos aplicativos móveis de instituições financeiras, o projeto visa não apenas proteger os clientes, mas também reduzir o impacto dos sequestros relâmpagos tanto para bancos quanto para usuários finais. Espera-se que esta pesquisa contribua para o campo da segurança cibernética em serviços financeiros, oferecendo uma abordagem inovadora para lidar com situações de risco extremo.

Palavras-Chave: negação plausível, fricção programável, segurança usável, sequestros relâmpagos, segurança bancária.

ABSTRACT

This graduation project was developed at the Polytechnic School of the University of São Paulo (Poli-USP). The work aims to implement plausible deniability (repudiation) in lightning kidnappings to create a panic mode in banking applications and mitigate the damage caused by this type of crime.

The advancement of the PIX system in Brazil has facilitated the transfer of financial resources between individuals but has also intensified cases of lightning kidnappings. The Public Prosecutor's Office and Febraban have highlighted the urgent need for new measures to curb this trend. The main goal is to protect users from unauthorized access to financial information during emergency situations, such as attempts to access under duress. The proposed system uses alternative passwords and temporarily alters the visible financial data to mitigate risks and enhance banking security.

Implemented in the mobile applications of financial institutions, the project aims not only to protect customers but also to reduce the impact of lightning kidnappings on both banks and end-users. It is expected that this research will contribute to the field of cybersecurity in financial services, offering an innovative approach to dealing with extreme risk situations.

Keywords: plausible deniability, programmable friction, usable security, lightning kidnappings, banking security.

LISTA DE FIGURAS

1	Excerto de solução proposta pela Febraban em 1997 no jornal <i>O Fluminense</i> para mitigar danos dos sequestros relâmpagos [1].	11
2	Aumento dos casos de extorsão mediante sequestro na cidade de São Paulo [2].	12
3	Funcionamento atual.	24
4	Fluxograma das principais situações no sequestro relâmpago.	24
5	Diagrama de sequência para o sistema atual de notificação do órgão de segurança em caso de fraude.	26
6	Diagrama do funcionamento de um sequestro com soluções em funcionamento.	27
7	Sequência da ocultação dos aplicativos.	28
8	Celular com token inserido na entrada para validar autenticidade do usuário. No caso da tag NFC, apenas a aproximação é suficiente.	29
9	Autenticação com letra/número mais digital para a entrada na conta real do usuário.	32
10	Diagrama de alto nível desde a autenticação do modo pânico até o chamado das forças públicas de segurança.	33
11	Alterações principais realizadas no perfil do usuário.	34
12	Etapas para a construção do perfil pânico.	35
13	Diagrama que representa em parte o fluxo de dados do estado de alerta até a notificação às autoridades policiais.	36

LISTA DE TABELAS

1	Mapa com os principais crimes com suas prevenções, com a ênfase para o sequestro relâmpago que delimita o escopo deste projeto.	13
2	Descrição dos casos de utilização de senhas alternativas.	31
3	Meios de coleta de dados, situações e ações tomadas. Saturação da cor indica intensidade da ação.	38
4	Dados gerais do usuário.	39
5	Dados pessoais.	40
6	Dados bancários.	41
7	Dados de segurança.	41
8	Dados bancários no modo pânico. Dados em vermelho correspondem a valores fictícios adicionados.	42
9	Matriz de Engajamento das Partes Interessadas	47
10	Matriz responsabilidade das Partes Interessadas	49
11	Matriz SWOT para identificação de riscos.	50
12	Matriz de confusão (ou matriz de erro). Visualização para resultados de algoritmo classificador.	52
13	Matriz de Probabilidade e Impacto	54

LISTA DE SIGLAS

MVC – *Model-View-Controller* (Modelo-Visão-Controlador)

MVP – *Minimum Viable Product* (Produto Mínimo Viável)

Febraban – *Federação Brasileira de Bancos*

ATM – *Automated Teller Machine* (Caixa Eletrônico)

PIX – *Pagamento Instantâneo* (Sistema de Pagamentos Instantâneos)

TED – *Transferência Eletrônica Disponível*

DOC – *Documento de Ordem de Crédito*

BACEN – *Banco Central do Brasil*

SUMÁRIO

1	Introdução	10
1.1	Histórico	10
1.2	Contexto atual	11
1.3	Motivação	12
1.4	Objetivos Gerais	14
1.5	Métodos	14
1.6	Justificativa	15
1.7	Organização do Trabalho	16
1.8	Estado da Arte	17
2	Aspectos Conceituais	19
2.1	Sequestro Relâmpago	19
2.2	Serviços básicos de segurança	19
2.3	Confidencialidade	19
2.4	Não-repúdio	20
2.5	Negação plausível	20
2.6	Segurança usável	20
2.7	Fricção programável	21
2.8	Arquitetura MVC	21
3	Método de Trabalho	22
4	Especificação de Requisitos	23
4.1	Sistema atual	23
4.1.1	Casos de uso	23

4.1.2	Diagrama de acionamento policial	25
4.2	Sistema com soluções propostas	27
4.2.1	Ocultação do aplicativo	27
4.2.2	Token/tag NFC	29
4.2.3	Custodiante	29
4.2.4	Modo pânico	30
4.2.4.1	Autenticação e modo pânico	30
4.2.4.2	Funcionamento do modo pânico	33
4.2.4.3	Ativação definitiva do perfil pânico	33
4.2.4.4	Construção do perfil pânico	34
4.2.4.5	Ativação do estado de alerta	36
4.3	Atores	38
4.3.1	Usuário	39
4.3.1.1	Dados gerais do usuário	39
4.3.1.2	Exemplos fictícios	40
4.3.1.3	Usuário no modo pânico	41
4.3.2	Instituições financeiras	42
4.3.2.1	Autenticação do usuário	43
4.3.2.2	Modo pânico	43
4.3.2.3	Comunicação com autoridades	43
4.3.3	Autoridades policiais	43
4.3.3.1	Software policial	44
4.3.4	Seguradoras	44
4.3.4.1	Modelo de negócios	44
5	Desenvolvimento do Trabalho	45
5.1	Análise das partes interessadas	45

5.1.1	Registro das partes interessadas	45
5.1.1.1	Instituições financeiras	45
5.1.1.2	Seguradoras	46
5.1.1.3	Usuários (vítimas potenciais)	46
5.1.1.4	Órgãos de segurança pública	47
5.1.1.5	Criminosos	47
5.2	Matriz RACI	48
5.3	Matriz SWOT	49
5.4	Análise de riscos	50
5.4.1	Modo pânico	51
5.4.1.1	Riscos de falso positivo	51
5.4.1.2	Riscos de falso negativo	51
5.4.1.3	Riscos sobre o modo pânico	52
5.4.1.4	Riscos de falhas no sistema	53
6	Considerações Finais	55
	Referências Bibliográficas	57

1 INTRODUÇÃO

1.1 Histórico

A versão original do Código Penal brasileiro, promulgada em 1940, já incluía a tipificação do crime de extorsão mediante sequestro entre os delitos catalogados. Contudo, o conceito e a tipificação do chamado sequestro relâmpago surgiram mais recentemente.

Uma pesquisa no acervo digital da Biblioteca Digital da Fundação Biblioteca Nacional [3] revela que o termo “sequestro relâmpago” surgiu nos periódicos brasileiros pela primeira vez na década de 1990. Desde então, o *modus operandi* dos criminosos vem se adaptando às novas tecnologias desenvolvidas ao longo do tempo.

Os primeiros caixas eletrônicos (ATMs) chegaram ao Brasil na década de 1980, enquanto os cartões de crédito magnéticos surgiram um pouco antes. Contudo, essas tecnologias só se tornaram amplamente populares na década de 1990. A facilidade de realizar saques rápidos nos caixas eletrônicos foi, por muito tempo, explorada como um dos principais mecanismos de facilitação para os sequestros relâmpagos.

A Secretaria de Segurança Pública do Estado de São Paulo mantém em sua base de dados [2] todas as ocorrências criminais desde 1995. No entanto, o crime de sequestro relâmpago não era categorizado de forma específica. Sua tipificação no Código Penal ocorreu apenas em 2009, quando foi incluído na seção de extorsão. Antes disso, tais crimes eram geralmente investigados como roubos, embora já houvesse uma tendência entre os promotores de enquadrar os envolvidos na categoria de extorsão mediante sequestro [4].

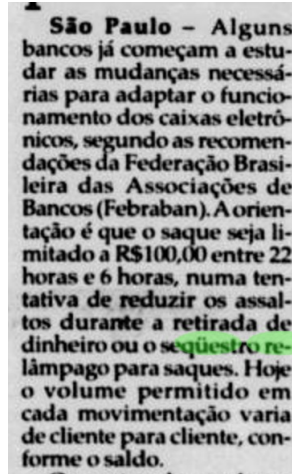


Figura 1: Excerto de solução proposta pela Febraban em 1997 no jornal *O Fluminense* para mitigar danos dos sequestros relâmpagos [1].

Embora as tecnologias tenham evoluído ao longo do tempo, a solução proposta pela Febraban para mitigar os danos causados pelos sequestros relâmpagos permanece a mesma. Como destacado em uma matéria de *O Fluminense* de 1997, ilustrada acima, a recomendação era limitar o montante disponível para saques em determinados horários do dia, uma medida que continua sendo defendida até os dias de hoje.

1.2 Contexto atual

Mais recentemente, a pandemia da COVID-19 desempenhou um papel significativo nesse contexto, gerando um aumento recorde no uso e no registro de plataformas bancárias digitais. Até o final de 2021, cerca de 38 milhões de brasileiros aderiram a esses serviços pela primeira vez [5]. Esse movimento foi impulsionado tanto por necessidades pessoais quanto pelas demandas de consumo durante o período de quarentena, levando muitos a migrarem suas transações financeiras para o ambiente digital.

No final de 2020, a implementação do PIX foi um marco tecnológico importante nesse novo ambiente digital. As transações passaram a ser realizadas de forma muito mais ágil em comparação aos antigos TEDs e DOCs, além de serem irreversíveis. Contudo, essa agilidade também atraiu a atenção de criminosos, que passaram a explorar o PIX como uma oportunidade para obter dinheiro rapidamente em diversos delitos, incluindo sequestros relâmpagos.

Ao longo dos anos, as instituições financeiras investiram no desenvolvimento de novas ferramentas de segurança, como senhas exclusivas para diferentes dispositivos de acesso e

autenticação por biometria digital e facial. Além disso, aprimoraram soluções já existentes, como a limitação de valores em transações, incorporando sistemas inteligentes. No entanto, essas iniciativas não foram suficientes para conter o aumento contínuo nos casos de sequestros relâmpagos.

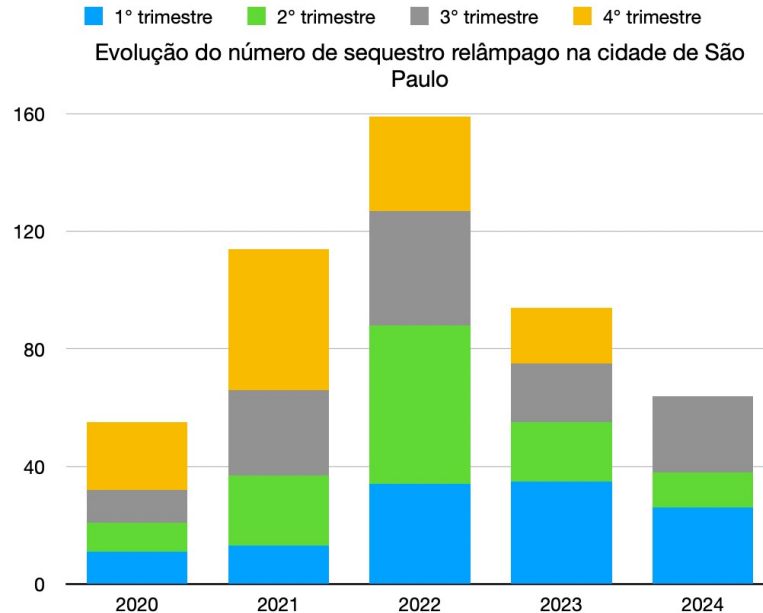


Figura 2: Aumento dos casos de extorsão mediante sequestro na cidade de São Paulo [2].

1.3 Motivação

Conforme ilustrado na Figura 2, 2022 registrou o maior número de casos, com um valor absoluto três vezes superior ao de 2020. Já em 2021, houve uma duplicação de casos em comparação a 2020. Embora os anos de 2023 e 2024 apresentem números inferiores a 2022, ambos ainda permanecem significativamente acima dos registrados em 2020. Vale destacar que os dados de 2024 ainda não incluem os casos do último trimestre, visto que esta dissertação foi elaborada nesse período. Mesmo assim, os valores acumulados nos três primeiros trimestres de 2024 já superam o total de 2020.

Em 2023, o Ministério Público destacou a necessidade de desenvolver novas soluções para enfrentar esse problema. Uma das propostas seria a inclusão da geolocalização durante a realização de transações via PIX, com o objetivo de possibilitar a identificação do flagrante delito, conforme indicado pelo promotor Barone [6]. No entanto, em novembro de 2024, o BACEN ainda foca em políticas de segurança que se restringem apenas à limitação do montante das transações financeiras [7].

Quase 30 anos após a proposta de limitação das transações financeiras feita pela

Febraban em 1997, o BACEN ainda mantém a mesma abordagem. Essa solução de segurança apresenta diversos inconvenientes para a usabilidade do usuário e não resolve efetivamente o problema. Este projeto surge justamente da necessidade de abandonar soluções arcaicas que não atacam o cerne do problema.

Os principais crimes realizados por meio dos aplicativos bancários estão detalhados na Tabela 1, a qual apresenta o tipo de crime conforme definido pelo Código Penal, o contexto em que ocorre, a forma de ameaça e as soluções atuais (A), bem como potenciais soluções futuras (S), discutidas posteriormente nesta dissertação. Este projeto visa apresentar soluções para o problema dos sequestros relâmpagos, situado na última linha da tabela 1.

Crime	Cenário	Ameaça	Prevenção
Estelionato qualificado (Art. 171)	Controle parental, auxílio a idosos	Engenharia Social	(A) Quórum mínimo de aprovadores
Invasão de dispositivo informático	Invasão de Dispositivo (Art. 154-A)	Malware/cracker	(A) Dispositivos de segurança adicionais
Estelionato qualificado (Art. 171)	Criptoativos	Contrato vulnerável, engenharia social	(A) Prevenir transação p/ contratos com score baixo
Extorsão mediante sequestro (Art. 159)	Sequestro: condição ou pagamento para resgate	Coerção ("Sequestro premeditado")	(A) Segurança física
Sequestro Relâmpago (Art. 157, § 2º, II)	Sequestro: curta ou longa duração para subtrair bens da vítima	Coerção ("Sequestro do Pix")	(A) Local não confiável (GPS) (A) Contas com score baixo (S) APP oculto (S) Solução Pânico

Tabela 1: Mapa com os principais crimes com suas prevenções, com a ênfase para o sequestro relâmpago que delimita o escopo deste projeto.

Atualmente, duas principais abordagens estão sendo utilizadas com o intuito de mitigar esse tipo de crime. Uma delas consiste em monitorar o GPS do dispositivo da vítima durante a transação do PIX, identificando se a operação está sendo realizada em um local seguro e conhecido, como a residência do próprio usuário, que já possui um histórico de transações. Em caso de suspeita de fraude e de um possível sequestro, o gerente da conta é

o responsável que entra em contato com as autoridades policiais informando a localização onde aconteceu o PIX.

A segunda abordagem é bloquear transferências para destinatários que possuem contas com baixa pontuação de confiança, geralmente associadas a contas recentemente criadas, possivelmente clonadas pelos golpistas para receber as transferências. Contudo, nenhuma das duas medidas se mostrou completamente eficaz na prevenção desse tipo de crime. Por isso, serão propostas as implementações de duas soluções: a solução por meio do **aplicativo oculto** e outra que chamamos de **solução pânico**.

1.4 Objetivos Gerais

Tendo em vista esse problema real em aberto, este trabalho tem como objetivo minimizar os danos do sequestro relâmpago utilizando o conceito da **negação plausível**. Para isso, é essencial garantir que o indivíduo sequestrado fique sob efeito coercitivo o menor tempo possível e que ele tenha o menor valor financeiro possível subtraído pelos sequestradores, tudo isso com o cuidado para que as soluções apresentadas não ameacem a integridade física da vítima que é o ativo mais importante deste projeto.

O desenvolvimento dessa ideia requer a implementação de um estado pânico nos aplicativos das instituições financeiras. Esse estado usará a negação plausível para que os criminosos não possam distinguir o estado pânico do estado normal do aplicativo. Dessa maneira, nesse estado pânico alterações serão realizadas para atingir o objetivo da maior redução de danos possível.

1.5 Métodos

i. Mapeamento do Sistema Atual

O primeiro passo no desenvolvimento de soluções de segurança é mapear os sistemas atuais dos aplicativos bancários, com foco específico em funcionalidades que possam prevenir ou mitigar impactos de situações de sequestro. Além disso, é necessário avaliar as soluções propostas e as soluções implementadas, analisar o impacto delas como solução ao problema proposto.

ii. Identificação de Lacunas e Problemas

Após o mapeamento, é crucial identificar as lacunas e os principais problemas no sistema atual. Isso inclui analisar criticamente as soluções implementadas e propostas.

A análise dessas lacunas ajuda a entender as áreas que necessitam de otimização, sendo fundamental para orientar o projeto na criação de novas soluções tecnológicas.

iii. Definição de Ativos e Requisitos

Com base nas lacunas identificadas, define-se os ativos do projeto, as partes interessadas e os requisitos funcionais necessários. Essa etapa envolve a análise dos papéis dos bancos, seguradoras, usuários e autoridades de segurança pública. Essa análise é essencial para propor soluções tecnológicas condizentes com a política de cada órgão desse e entender o quão eles estarão envolvidos no projeto.

iv. Análise e Aceitação de Riscos

Por fim, realiza-se um processo de análise de riscos, que engloba a identificação, análise e avaliação dos riscos associados ao sistema e às novas soluções. Essa etapa permite propor estratégias de tratamento do risco, garantindo que as soluções sejam eficazes e aceitas pelos stakeholders. O objetivo é equilibrar a segurança com a experiência do usuário, assegurando que os riscos sejam mitigados de forma prática e alinhada às expectativas.

1.6 Justificativa

Ao longo do tempo, o sistema financeiro vem aperfeiçoando o nível de segurança de seus sistemas. Com a maior utilização do sistema bancário de maneira digital (Internet Banking), foram criadas diferentes tipos de senha. Em geral, os bancos utilizam a senha com quatro dígitos para o cartão, seis dígitos para confirmação da transferência via aplicação e uma senha de oito dígitos para o acesso inicial ao aplicativo [8]. Variações entre as instituições financeiras existem, mas não mudam o cerne das ideias apresentadas.

Evidentemente que a criação desse conjunto de senhas não evitou a continuação de crimes. Qualquer indivíduo que possuísse esse conjunto de senhas poderia realizar todas as transações que desejasse pelo aplicativo. Para solucionar esse problema de autenticação do usuário, foi implementada a opção de validação biométrica, mais recentemente foi desenvolvida a biometria facial que agrega um nível extra de validação do usuário responsável pelas transações [9].

No entanto, nenhuma dessas tecnologias de autenticação resolve o problema de um indivíduo que está sob coação física (escopo desse trabalho). A solução pela negação plausível surge para responder essa demanda.

1.7 Organização do Trabalho

Este trabalho é organizado em seis tópicos principais, cada um contribuindo para uma compreensão abrangente e sistemática do projeto de engenharia proposto. A seguir, são delineados os conteúdos que serão abordados em cada seção:

Na **introdução** é apresentado o histórico, os dados estatísticos, o contexto geral do projeto, delineando a importância e a relevância da pesquisa sobre negação plausível em sequestros relâmpagos. Serão destacados os objetivos, a motivação por trás do estudo e uma visão geral da estrutura do trabalho.

Os **aspectos conceituais** fornecerão um embasamento teórico sobre os conceitos fundamentais relacionados ao projeto, desde as propriedades fundamentais de segurança, até a conceituação de sequestro relâmpago. Esses conceitos-chave são essenciais para um bom entendimento das soluções e problemáticas apresentadas no projeto.

No **método de trabalho** é descrito o método utilizado para conduzir a pesquisa, incluindo abordagens de investigação, coleta de dados, ferramentas computacionais e experimentos planejados. Será detalhado como a metodologia escolhida será aplicada para alcançar os objetivos propostos.

Na **especificação de requisitos** definirá requisitos funcionais e não funcionais do sistema proposto, identificando as necessidades dos usuários, os cenários de uso e as restrições do projeto. Será elaborada uma lista completa e detalhada dos requisitos que o sistema deve atender.

No **desenvolvimento do trabalho** será apresentado o processo de implementação do sistema de negação plausível em sequestros relâmpagos, desde a concepção até a fase de testes e validação. Serão discutidas as etapas de desenvolvimento de software, algoritmos utilizados e decisões de design tomadas durante o processo.

Por último, nas **considerações finais** serão apresentadas as conclusões do trabalho, incluindo *insights* obtidos, contribuições para a área de estudo e possíveis direções para pesquisas futuras. Será feita uma reflexão sobre os resultados alcançados em relação aos objetivos inicialmente propostos.

1.8 Estado da Arte

No campo da segurança digital em sistemas bancários, o estado da arte revela algumas implementações de medidas preventivas contra crimes cibernéticos, embora poucos tenham sido especificamente direcionados aos sequestros relâmpagos.

Soluções adotadas pelos bancos, como autenticação multifatorial, criptografia avançada e sistemas de alerta precoce, têm sido exploradas para proteger os usuários contra acessos não autorizados e garantir a integridade das transações financeiras. Além disso, novas abordagens como a ocultação do aplicativo e/ou valores, ou ainda, a restrição de transações via PIX com base na localização do usuário, têm sido levantadas como resposta direta ao aumento dos crimes relacionados ao uso dessas tecnologias.

Nesse sentido, no final de 2022 o banco NuBank criou o “modo rua” [10]. Essa opção foi ofertada ao usuário com o intuito de limitar a quantia das transações fora de uma rede Wi-Fi pré-definida. No segundo semestre de 2024, a carteira digital PicPay criou o modo “seguro”, com as opções de saldos “protegido” e “invisível” [11]. Esse modo é parecido com o modo rua, mas utilizando geolocalização, ao invés da localização por uma rede Wi-Fi. As soluções apresentadas se limitam a restrição do pix ou a segurança por ocultação de serviços e valores, elas não usam o conceito de negação plausível em sua totalidade tal qual ela é exposta neste trabalho.

Vale destacar que as soluções apresentadas acima podem desencadear ações violentas por parte dos criminosos como demonstraremos neste trabalho e que somente a implementação correta da solução por negação plausível é capaz de mitigar. Vale pontuar que as instituições financeiras estão tentando achar soluções para os casos de roubo e furto, e em todas essas tentativas existe o entendimento que a coparticipação do usuário é necessária para melhor adaptação da solução, relacionando-se assim os conceitos de segurança usável e fricção programável.

Em 2024, alguns aplicativos têm sido utilizados para ocultar outros apps e proteger a privacidade no sistema Android, com destaque para o *App Hider*, *Hide It Pro* e *Vault*. Esses aplicativos permitem ocultar aplicativos sensíveis e arquivos pessoais por meio de senhas ou PINs, oferecendo uma camada adicional de segurança para os usuários [12]. No entanto, foram identificadas vulnerabilidades no uso dessas ferramentas. Por exemplo, ao buscar esses aplicativos na Play Store, eles ainda são visíveis, o que compromete parcialmente a discrição oferecida. Destaca-se que a opção de esconder os aplicativos é uma opção nativa em alguns tipos de celulares modernos.

Adicionalmente, aplicativos de segurança, como *Life360* e *bSafe*, ganharam destaque como mecanismos para proteger os usuários contra situações de risco, incluindo sequestros relâmpagos. Esses aplicativos oferecem funcionalidades como rastreamento em tempo real, envio automático de alertas de emergência e compartilhamento de localização com contatos de confiança, o que contribui para o aumento da segurança pessoal em contextos de emergência. No entanto, uma limitação importante é que, apesar de melhorarem a comunicação e rastreamento, nenhum deles oferece uma solução para evitar a subtração de valores financeiros de contas bancárias em momentos de risco.

A própria Febraban destaca a urgência de soluções adaptáveis, considerando que os principais usuários dessas ferramentas nem sempre possuem pleno domínio de sua utilização e frequentemente estão em estado emocional abalado durante um sequestro. Isso reforça a necessidade de respostas eficazes por parte das instituições financeiras e regulatórias para enfrentar essa problemática.

No início de 2023 o promotor Barone conversou com a Febraban sobre a importância de se adicionar a geolocalização nos aplicativos bancários como forma de coibir as ações de sequestro relâmpago [6]. No entanto, até o presente momento a Febraban e o Banco Central continuam com medidas de segurança que não abarcam diretamente o problema do sequestro relâmpago. Em Novembro de 2024, foram divulgadas novas medidas que envolvem mais restrição do montante do PIX envolvendo o tipo de dispositivo e o aperfeiçoamento da identificação de transações atípicas [13].

Nesse contexto, as soluções propostas neste projeto representam um grande avanço. Primeiro pelo uso da negação plausível em sua totalidade, o uso da geolocalização para identificação da localidade das transações e o aviso automático às autoridades policiais.

2 ASPECTOS CONCEITUAIS

2.1 Sequestro Relâmpago

Ainda no levantamento de requisitos deste projeto, foram feitas entrevistas com alguns atores envolvidos neste processo. Segundo o delegado de polícia da delegacia anti-sequestro Rafael Guimarães Lodi, o **sequestro relâmpago** mudou o perfil nos últimos anos, se antes eles sequestravam o indivíduo para ir até caixas eletrônicos e retirar o dinheiro, hoje existem facilidades como o PIX que ajudam esse tipo de sequestro.

Ainda segundo o delegado, na cidade de São Paulo o público alvo tem sido homens vítimas do que se chama de “golpe do amor”, nessas redes esses homens se expõe financeiramente, e portanto, cria-se uma expectativa alta de retorno do crime cometido por parte dos sequestradores. Após o sequestro e leitura dos dados bancários da vítima, normalmente ocorre a ratificação da expectativa inicial.

2.2 Serviços básicos de segurança

Dentre as propriedades básicas da segurança da informação, esse projeto trabalha diretamente com as propriedades da **Confidencialidade** e do **Não-repúdio**. Quanto às demais propriedades como disponibilidade, integridade e autenticidade, assume-se que funcionarão normalmente como no sistema atual.

2.3 Confidencialidade

A **Confidencialidade** possui dois vieses importantes. O primeiro trata da confidencialidade dos dados, os dados privados ou confidenciais não podem estar disponíveis para indivíduos não autorizados. O segundo trata do conceito de privacidade, que pode ser entendida também como confidencialidade das entidades, nela os indivíduos controlam quais informações relacionadas a eles podem ser coletadas e armazenadas e por quem e

para quem essas informações podem ser divulgadas [14].

A confidencialidade dos dados pode ser garantida eficientemente por criptografia (e.g., envio de dados por um meio não seguro) ou ainda pela negação plausível que não mostra os dados reais a um terceiro. O criminoso não pode ter a capacidade de discernir em qual modo o usuário está acessando o sistema, se os valores mostrados na tela são reais ou não, idealmente ele não deve saber nem mesmo se o usuário tem ambas as opções de login disponíveis.

2.4 Não-repúdio

O não-repúdio fornece garantia da origem ou entrega de dados, a fim de proteger o remetente contra a falsa negação por parte do destinatário de que os dados foram recebidos, ou para proteger o destinatário contra a falsa negação por parte do remetente de que os dados foram enviados [15]. Alguns autores preferem tratar esse princípio como parte de um princípio maior como auditabilidade [14].

2.5 Negação plausível

Pode ser entendida como uma extensão do conceito de repudiation, definido como “uma entidade engana outra ao negar falsamente a responsabilidade por um ato” [16]. Mais especificamente, a negação plausível permite que um usuário negue a existência de determinados dados armazenados, mesmo que um adversário tenha acesso ao meio de armazenamento [17].

A ausência da irretratabilidade, nesse contexto, pode ser vista como uma característica que contribui para a segurança. Neste projeto, o conceito é aplicado para permitir que o usuário negue acesso aos seus dados reais, de forma que um terceiro não consiga distinguir se está acessando o modo normal ou o modo pânico.

2.6 Segurança usável

Segurança usável refere-se ao design de sistemas que oferecem proteção robusta contra ameaças, mas de forma intuitiva e acessível, garantindo que os mecanismos de segurança não sejam tão complicados ou intrusivos que afastem ou confundam o usuário legítimo.

Whitten e Tygar em seu artigo *Why Johnny Can't Encrypt* definem que um software

seguro é usável se os usuários: estão cientes das tarefas de segurança que necessitam executar, são capazes de descobrir como executar suas tarefas com êxito, não cometem erros perigosos e estão suficientemente confortáveis com a interface [18].

Portanto, o foco é criar soluções que não apenas protejam os dados e transações, mas também reduzam o esforço cognitivo e operacional necessário para utilizá-las. Exemplos já consolidados incluem autenticação biométrica fácil de usar, interfaces claras que ajudam a identificar atividades suspeitas e fluxos de navegação que não criem frustrações desnecessárias.

2.7 Fricção programável

Fricção programável é a introdução deliberada de barreiras ou etapas adicionais em processos de interação, ajustadas dinamicamente com base no nível de risco. Diferentemente de aplicar as mesmas medidas de segurança para todos os usuários e situações, a fricção programável permite respostas personalizadas e contextuais. Por exemplo, em uma transação considerada de alto risco, como o envio de dinheiro para uma conta desconhecida, o sistema pode exigir validação extra, como um código enviado por SMS ou autenticação biométrica. Em transações de baixo risco, essas etapas podem ser omitidas, oferecendo uma experiência mais fluida.

2.8 Arquitetura MVC

A arquitetura MVC (*Model-View-Controller*) é uma abordagem de desenvolvimento de software que promove a separação de responsabilidades em um aplicativo. Desse modo, o sistema é dividido em três componentes principais: Modelo, Visão e Controlador. Essa divisão facilita a organização do código, tornando o sistema mais modular. Esse padrão arquitetural foi utilizado no desenvolvimento do protótipo deste projeto.

3 MÉTODO DE TRABALHO

O método de trabalho para o desenvolvimento do projeto seguirá uma abordagem estruturada em etapas específicas, conforme descrito a seguir:

O primeiro passo será o mapeamento do sistema atual. Essa etapa envolverá a análise detalhada dos aplicativos bancários já existentes, com foco especial nas funcionalidades que possam prevenir ou mitigar os impactos de situações de sequestro relâmpago. Além disso, será realizada uma avaliação crítica tanto das soluções já implementadas quanto das propostas, analisando o impacto dessas medidas na solução do problema.

Após o mapeamento, será feita a identificação de lacunas e problemas. Essa fase consistirá em analisar criticamente as deficiências e limitações do sistema atual, com o objetivo de compreender quais áreas precisam de otimização. Essa análise é crucial para guiar o projeto na criação de novas soluções tecnológicas que sejam inovadoras e eficazes.

Com base nas lacunas identificadas, passaremos para a definição de ativos e requisitos. Nessa etapa, será estabelecido quais são os ativos do projeto, as partes interessadas e os requisitos funcionais necessários. A análise incluirá o papel desempenhado por bancos, seguradoras, usuários e autoridades de segurança pública. É essencial compreender a política e o envolvimento de cada uma dessas entidades para propor soluções tecnológicas alinhadas às suas expectativas e responsabilidades.

Por fim, será realizada uma análise e aceitação de riscos. Esse processo incluirá a identificação, análise e avaliação dos riscos associados ao sistema atual e às novas soluções propostas. Com base nessa análise, serão sugeridas estratégias para tratar os riscos, garantindo que as soluções desenvolvidas sejam eficazes e aceitas pelos *stakeholders*. O equilíbrio entre segurança e experiência do usuário será uma prioridade, assegurando que as medidas propostas atendam tanto aos requisitos técnicos quanto às expectativas práticas.

4 ESPECIFICAÇÃO DE REQUISITOS

Após a pesquisa e análise do funcionamento dos sistemas bancários, foram elaborados casos de uso focados nos sistemas de autenticação, no acesso aos aplicativos atuais e no fluxo lógico em situações de sequestro. Esse processo aprofunda a compreensão do cenário atual, fundamenta o desenvolvimento dos requisitos do projeto e estabelece uma base sólida para a criação dos casos de uso das soluções propostas.

4.1 Sistema atual

Os casos de uso descritos são compostos pelos atores usuário, dispositivo móvel e banco, que interagem entre si para fornecer os serviços financeiros aos usuários. Adicionalmente outros atores como gerente, polícia e criminosos compõem com os atores anteriores os casos de uso durante a ação criminosa.

4.1.1 Casos de uso

A figura abaixo ilustra o caso de uso em que a vítima é o ator principal durante um sequestro. O fluxo lógico é conduzido pelas ações e decisões, geralmente guiadas pelos sequestradores, embora estes não estejam explicitamente representados no caso de uso.

Durante o sequestro, os criminosos iniciam uma investigação sobre a vida financeira da vítima, verificando se ela possui contas bancárias, qual é sua renda e quais características ou recursos estão associados às suas contas.

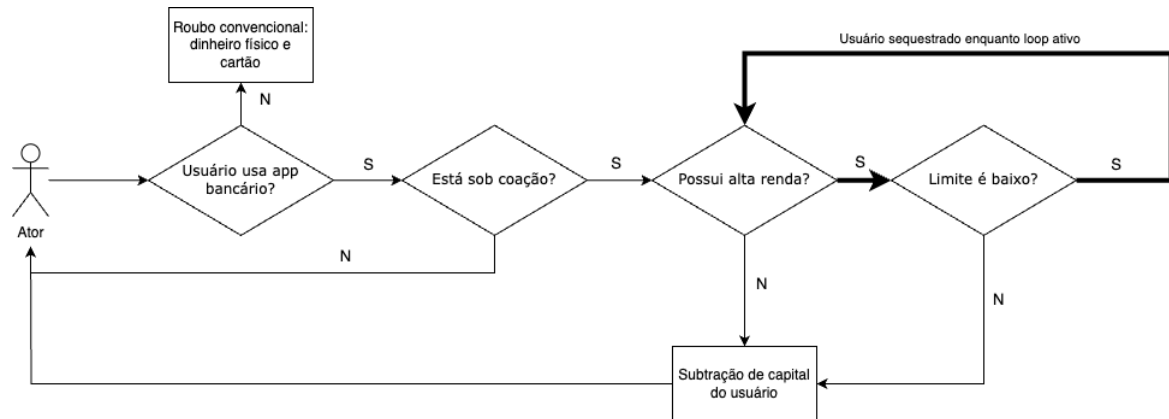


Figura 3: Funcionamento atual.

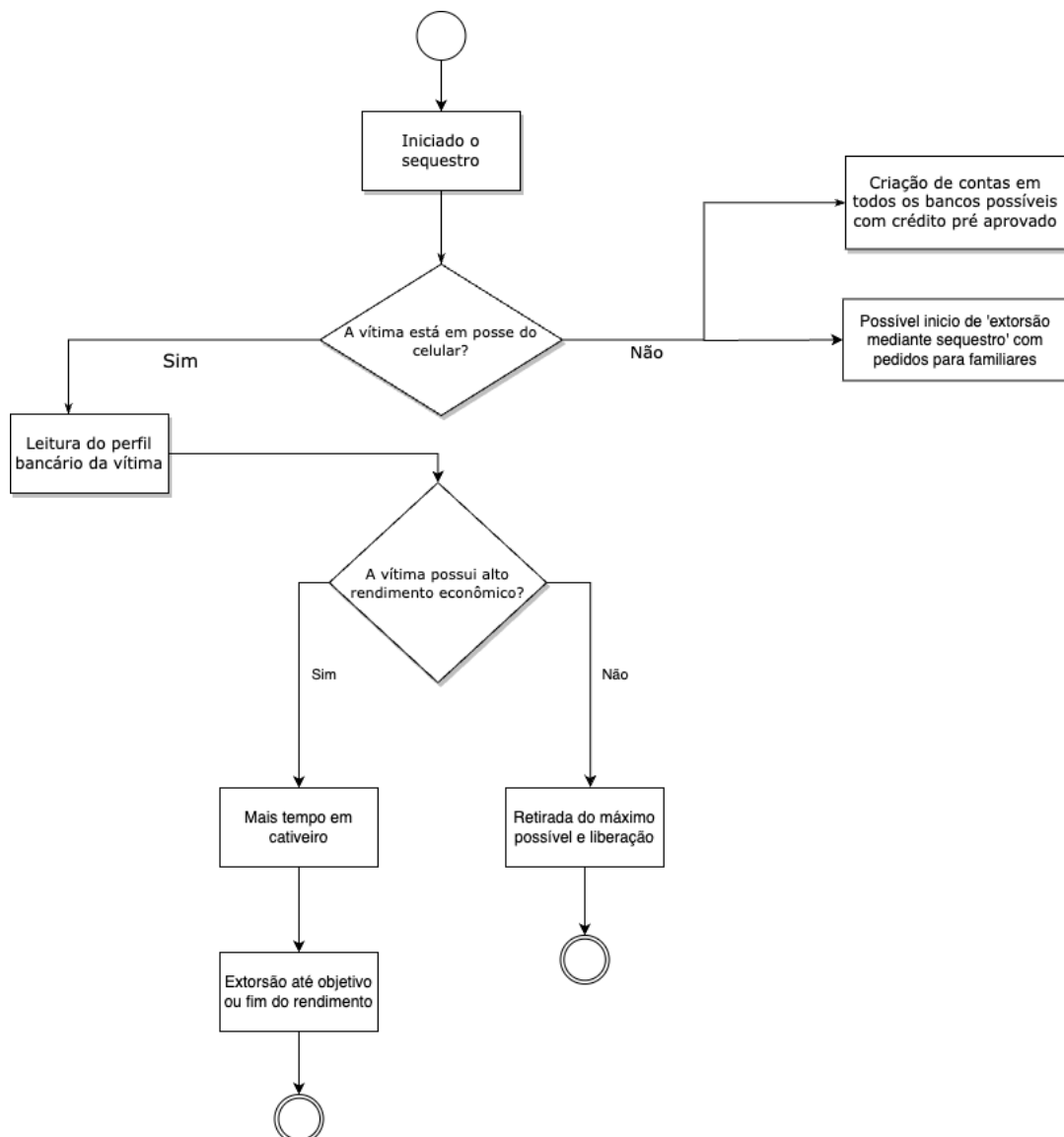


Figura 4: Fluxograma das principais situações no sequestro relâmpago.

Após a investigação inicial, os criminosos avaliam o potencial de roubo dos ativos

da vítima. Quando identificam um alto potencial econômico, como um saldo bancário elevado ou grandes investimentos, decidem prolongar o tempo de sequestro. O indivíduo de alto perfil permanece sob coação, como ilustrado no *loop* da seta em negrito na figura 3, até que o máximo possível de recursos seja subtraído.

Para potencializar a subtração de ativos, os criminosos recorrem a diversos mecanismos. Eles maximizam os limites de saques e transferências, resgatam antecipadamente todos os investimentos possíveis e solicitam empréstimos pré-aprovados automaticamente pelo banco. Em seguida, iniciam a subtração por meio de transferências via PIX para terceiros, pagamento de boletos, transferências de criptomoedas, entre outras ações.

A solução para mitigar o dano causado pela ação criminosa passa pela equação entre a expectativa inicial e o retorno obtido. No sequestro relâmpago, o perfil da vítima é presumido antes da ação. Os criminosos avaliam o poder aquisitivo da vítima com base em indicadores como a região de captura, o tipo de veículo utilizado e até mesmo o nível de vestuário. Portanto, uma abordagem eficaz implica na criação de um perfil fictício que seja plausível para a vítima, mas que não revele informações reais.

Em certos casos, será imperativo ocultar detalhes, como os investimentos; em outras situações, simular valores inferiores aos reais, como nos créditos ou nos saldos (de contas correntes e poupanças), torna-se uma medida estratégica. Em geral, uma medida eficaz para todos os públicos é a de aumentar os gastos do usuário no modo pânico, mesmo usuários de alta renda que costumam ter alto fluxo de entrada, podem possuir também alto fluxo de saída e isso deve ser usado como forma de aumentar a verossimilhança do modo pânico com o modo normal.

4.1.2 Diagrama de acionamento policial

Atualmente, não há diferenciação no acesso entre o usuário legítimo e o sequestrador quando ambos possuem a senha de acesso ao aplicativo bancário. Em casos de transferências incomuns realizadas pelo cliente — como valores elevados ou transações para destinatários previamente identificados em fraudes — o sistema bancário pode acionar automaticamente o gerente. Caso o gerente considere necessário, ele pode acionar os órgãos de segurança pública.

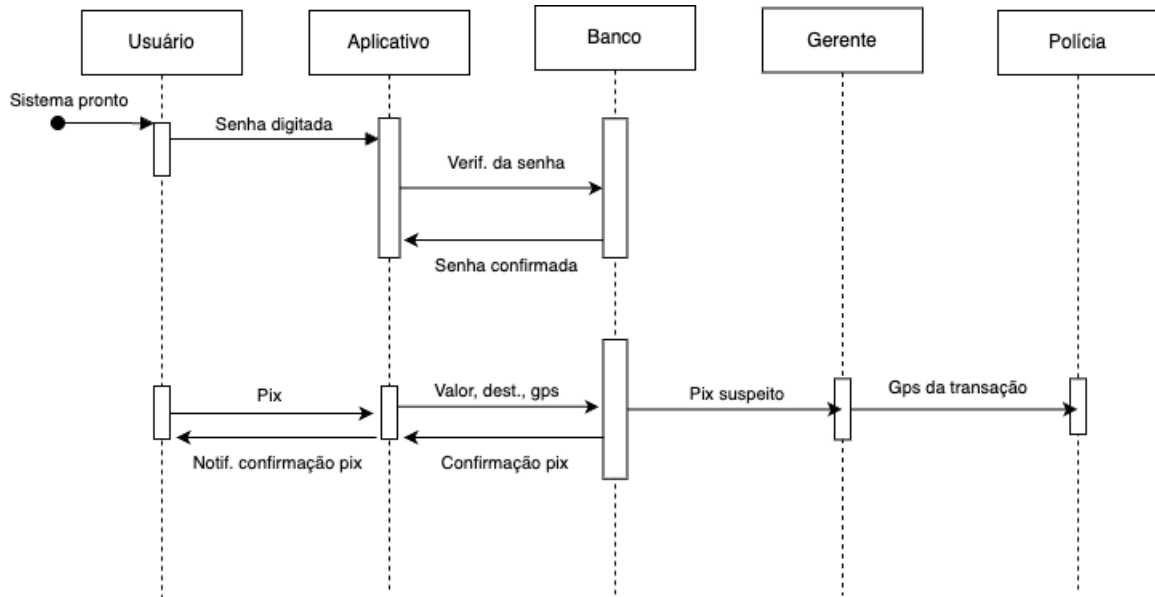


Figura 5: Diagrama de sequência para o sistema atual de notificação do órgão de segurança em caso de fraude.

A figura acima apresenta um diagrama de sequência que demonstra o funcionamento atual. O ator usuário entra e faz login no aplicativo do banco, após isso ele está autorizado para realizar transferências de acordo com as especificações da sua conta. Se a A figura acima apresenta um diagrama de sequência que demonstra o funcionamento atual. O ator usuário entra e faz login no aplicativo do banco, após isso ele está autorizado para realizar transferências de acordo com as especificações da sua conta. Se a transferência de PIX ocorre como habitual, o gerente não precisa ser comunicado, mas em caso de discrepância com as suas transações normais, o gerente é acionado e ele pode contactar a polícia. Muitas vezes outra senha é pedida para a efetivação do PIX, mas a ideia central permanece a mesma.

Tendo em vista esse funcionamento, nem todas as transações via PIX feitas pelo sequestrador serão notificadas ao gerente, e mesmo em caso de notificação, cabe a um humano a decisão final de notificar os órgãos de segurança competentes. Nessas duas etapas muitas falhas podem acontecer, seja erro do sistema que identifica transferências não-usuais, seja pelo gerente que pode deixar escapar uma transferência numa situação de risco como o sequestro.

O cerne da solução deste projeto passa por um sistema de autenticação que reconheça a diferença e dê acesso a dois modos distintos para o mesmo usuário, o que chamamos de modo pânico e modo normal, e apesar das funcionalidades do aplicativo continuarem absolutamente iguais, alguns atributos da conta do cliente serão alterados. Além disso, o

sistema bancário não armazenará somente a localização no momento do PIX, em caso de entrada no modo de pânico, o sistema bancário terá acesso à localização em tempo real do aparelho, a sua câmera e ao microfone.

4.2 Sistema com soluções propostas

Modus operandi ideal com soluções

O esquema da figura abaixo segue o mesmo grau de abstração do esquema da figura 3, no entanto, aqui temos o fluxo de ações tendo em vista as implementações mostradas na tabela 1. As soluções modo pânico e ocultação do aplicativo levam ao objetivo geral de otimização da redução de danos: o usuário fica sob coerção o menor tempo possível e tem a menor soma de dinheiro subtraída.

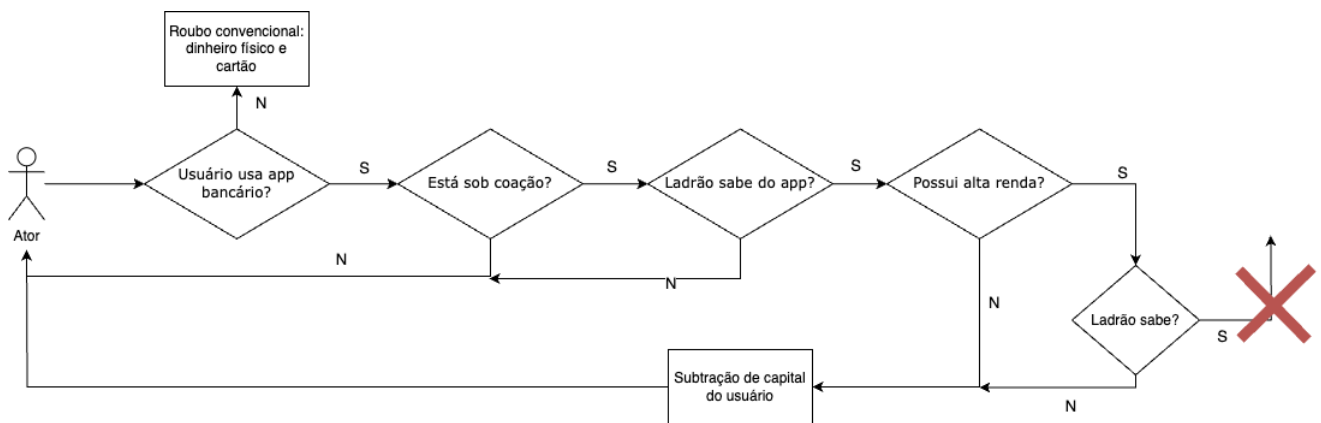


Figura 6: Diagrama do funcionamento de um sequestro com soluções em funcionamento.

4.2.1 Ocultação do aplicativo

A pergunta “Ladrão sabe do app?” consiste na solução de ocultações dos aplicativos bancários, se o criminoso não sabe da existência do aplicativo, teoricamente ele não irá tentar coagir a vítima a entrar no sistema bancário. Em teoria nenhuma soma de dinheiro é subtraída.

No entanto, de acordo com o delegado Lodi, nos casos em que as vítimas não possuem contas bancárias ou têm contas apenas em determinados bancos, os criminosos costumam criar novas contas em instituições nas quais a vítima não tenha vínculo. Se a vítima possui alto poder aquisitivo e boa renda em outros bancos, ele provavelmente terá crédito pré-aprovado no novo banco.

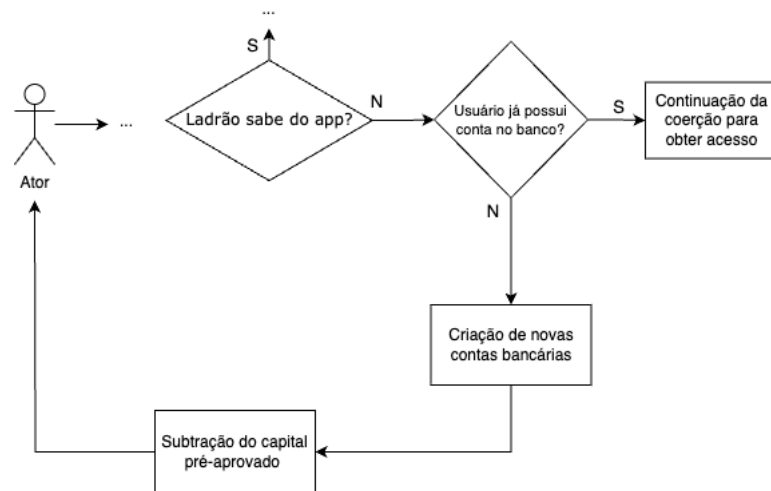


Figura 7: Sequência da ocultação dos aplicativos.

As consequências dessa situação são extremamente graves tanto para os bancos para o usuário. Muitas vezes a vítima só toma conhecimento de que possui uma dívida no novo banco meses após o sequestro, quando começam a chegar as faturas.

A solução pela ocultação do aplicativo possui dois principais tipos de riscos que acontecem no momento em que o criminoso tenta criar uma nova conta bancária para realizar empréstimos pré-aprovados no nome da vítima. O primeiro acontece se vítima já possuir conta e o banco notificar que ela já é seu cliente, a solução da ocultação não funcionou e a extorsão continua. O segundo caso é quando a vítima realmente não é seu cliente e o banco abre uma conta em seu nome e libera um crédito pré-aprovado, é necessário buscar uma solução para a não permissão de empréstimos em seu nome.

Para solucionar o primeiro risco, não se deve dar indícios que o usuário já possui conta naquela instituição financeira. Caso o usuário já tenha um cadastro de conta com modo pânico, é preferível que se deixe criar a nova conta, no entanto, sem saldo disponível para empréstimo ou com valor de empréstimo imediato muito baixo. É possível deixar o perfil em análise de crédito por “30 dias úteis” o que frustrará a continuação do golpe.

Já no segundo caso, uma forma de mitigar seria com um sistema interoperável de comunicação entre os bancos. Os usuários que possuem contas com modo pânico podem decidir no momento da personalização de sua conta pânico, em negar crédito facilitado de maneira automática por outras instituições financeiras. Além disso, esse sistema interoperável poderia ativar o modo pânico em todas as contas bancárias do cliente de uma vez só, protegendo assim todas as contas ao mesmo tempo. A comunicação entre as instituições financeiras é essencial nesta solução.

No segundo caso, ainda há a possibilidade de transferir o risco. A instituição financeira, ao permitir que o usuário personalize sua conta pânico, oferece, por meio de sua seguradora, um seguro anti-sequestro que cobre esse tipo de dano patrimonial, com extensões para seguro de vida e outras coberturas relacionadas.

Soluções multifator

4.2.2 Token/tag NFC

Para os usuários de altíssima renda, é razoável existir um nível de autenticação a mais. Propõe-se um modo que chamamos de *“daily”* em que ele poderia usar normalmente sem acionamento da polícia, mas com todos os valores de renda e investimento mais abaixo por padrão. No *“daily”* ele poderia realizar seus gastos do dia a dia.

No caso em que ele precise entrar no modo normal, ele usaria um token ou uma tag NFC. Sem esse token/tag, ele só poderia acessar o modo pânico ou o modo *“daily”*. Essa solução é uma solução que envolve autenticação multi-fator, incluindo algo que ele possui com algo que ele sabe.

Dentre as soluções existentes atualmente, a solução “modo rua” do Nubank não oculta ou altera os valores de saldos e investimentos do usuário, ela apenas altera o valor de transferência limite para regiões fora de um Wi-Fi designado seguro pelo usuário. No nosso modelo, o modo “daily” faria essas alterações.



Figura 8: Celular com token inserido na entrada para validar autenticidade do usuário. No caso da tag NFC, apenas a aproximação é suficiente.

4.2.3 Custodiante

Uma outra solução envolve a autorização de um custodiante. Esse custodiante pode ter duas atribuições (não exclusivas): autorizar a autenticação da conta do usuário ou validar a transação financeira.

Inicialmente, essa abordagem é vista como uma alternativa para auxiliar os idosos ou ainda como uma medida contra a engenharia social. Contudo, ela também pode ser eficaz na prevenção de perdas financeiras substanciais em casos de sequestro relâmpago. Por exemplo, se um casal configurar previamente a necessidade de autorização do cônjuge para transferências superiores a 10 mil reais, é possível impedir o roubo de valores acima desse limite pré-estabelecido.

Da mesma forma, em cenários em que o acesso à conta conjunta ou à conta no modo normal dependa da autorização de ambos os celulares, essa medida pode evitar ações fraudulentas durante uma situação de risco. Essa solução também poderia ser usada em contas empresariais onde todos os sócios teriam que autorizar o acesso ou transferências relacionadas a conta da pessoa jurídica.

4.2.4 Modo pânico

O acesso negado ao sim na pergunta “Ladrão sabe?” da figura 6 pode ser feito pela aplicação da solução pânico. O modo pânico nega ao criminoso a possibilidade de confirmar a renda da vítima, ele nunca saberá se o que está observando no aplicativo é a situação real da vítima ou se é o modo pânico em ação.

Os criminosos saberem da existência da solução pânico não altera a eficiência de seu funcionamento, pois somente o usuário tem a capacidade de saber se ele possui ou não essa solução, ou ainda, se essa solução está ativa ou não naquele momento. O termo negação plausível vem da possibilidade da vítima poder negar acesso do modo normal ao criminoso sem que o criminoso saiba qual modo está acessando.

Para o caso em que a vítima entre no modo pânico e o criminoso suspeite que não é a verdadeira conta, de nada adiantará coagir a vítima a colocar a outra senha, pois os valores disponíveis para roubo irão diminuir a cada troca de senha. O estado pânico permanecerá como o status fixo do sistema e não retornará enquanto o dono da conta não for em segurança numa agência física reverter esse status da sua conta.

4.2.4.1 Autenticação e modo pânico

Em geral, os sistemas bancários tem duas senhas principais, a senha para o acesso ao aplicativo com 8 ou 6 dígitos dependendo do banco, e a senha forte de validação da transação bancária, em geral de 6 dígitos. Para ativação do modo pânico, o usuário teria uma senha alternativa para cada uma delas. Chamaremos de senha fraca a senha de

entrada no aplicativo, a senha forte para a senha de validação de transação financeira e as senhas alternativas para as senhas fracas e fortes que ativam o modo pânico. A tabela abaixo descreve o funcionamento dos casos de uso.

Caso	Ação
Uso das senhas alternativas fraca e forte	Ativação do modo pânico com todas as suas funcionalidades características.
	Após a utilização da senha alternativa forte para validar a transação, será gerado um alerta máximo de intrusão.
Uso apenas da senha alternativa fraca	Ativação do modo pânico com todas as suas funcionalidades características, enquanto o sistema inteligente de verificação de usuário utiliza outros parâmetros para a tomada de decisão em relação à intervenção policial.
Uso apenas da senha alternativa forte	Perfil pânico não é ativado. Começo do registro de dados de câmera, áudio e GPS. O sistema inteligente irá decidir com esses e outros parâmetros alertar ou não as autoridades policiais.

Tabela 2: Descrição dos casos de utilização de senhas alternativas.

Dada a ativação do modo pânico, a senha de acesso ao modo normal ainda continua válida. No entanto, em caso de acesso à conta por meio da senha normal após um uso da senha alternativa, os valores de renda serão ainda mais baixos que os do primeiro acesso. Explica-se: a vítima entra em sua conta no modo pânico, alega ao criminoso que aquela é sua conta no modo normal, o caso em que o criminoso insiste para a vítima coloque a segunda senha, deve-se baixar ainda mais os valores como se a senha normal ativasse então o modo pânico.

Dessa forma, a vítima sempre poderá afirmar que entrou a primeira vez no modo normal (mesmo que não seja verdade). O criminoso nunca poderá validar essa informação. A partir do momento em que esse *modus operandi* for estabelecido e conhecido pelos criminosos, eles serão obrigados a se contentar com o montante disponível no primeiro acesso já que um segundo login com outra senha sempre resultará na redução do valor disponível para roubo e não permitirá que ele retorne ao valor exibido no primeiro acesso.

É costumeiro a realização da primeira autenticação pela biometria digital cadastrada para destravar o celular. Considerou-se a possibilidade de designar apenas um dedo como autenticador real do sistema, enquanto os demais ativariam o modo pânico. No entanto,

essa abordagem apresenta um problema: na prática, a maioria dos usuários utiliza apenas dois dedos para essa função, geralmente o indicador ou o polegar. Além do que, mesmo escolhendo um dedo aleatoriamente, a probabilidade de 10% para acessar o modo normal ainda seria muito alta.

Uma solução proposta seria a inclusão de uma etapa anterior à leitura da digital. Antes de posicionar o dedo no leitor, o usuário desenharia na tela um número ou uma letra, sem que o desenho fosse exibido. Caso essa etapa fosse ignorada ou realizada incorretamente, o modo pânico seria ativado. Com esse artifício, seriam adicionadas 36 novas possibilidades, e, combinadas com a digital, a probabilidade de uma combinação aleatória acessar a conta real do usuário seria reduzida para menos de 0.3%. Para efeito de comparação, a NIST SP 800-63B estabelece que um sistema biométrico deve trabalhar com uma taxa máxima de falha de 0.1%. Provando-se assim uma ordem de grandeza razoável para a solução proposta.

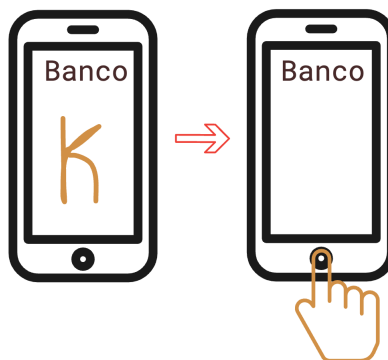


Figura 9: Autenticação com letra/número mais digital para a entrada na conta real do usuário.

Solicitar duas entradas aumentaria significativamente a segurança. Contudo, isso prejudicaria a experiência do usuário, contrariando o conceito de segurança usável. No entanto, outras combinações de fatores e métodos de autenticação são possíveis e podem resolver o problema.

Neste projeto específico, as biometrias digital e facial não resolvem o problema do sequestro relâmpago, pois a vítima está fisicamente sob coerção no local. Além disso, a NIST SP 800-63B evidencia que a biometria, seja qual for, não deve ser usada isoladamente, devendo sempre ser combinada com outros fatores de autenticação, mesmo em situações normais de não perigo.

4.2.4.2 Funcionamento do modo pânico

Após a primeira autenticação com a senha alternativa fraca, duas ações simultâneas são acionadas no sistema. A primeira é a *ativação do perfil de pânico coerente*, que corresponde ao perfil do usuário com a modificação dos parâmetros. A palavra “definitiva” no diagrama é utilizada para enfatizar que, uma vez que o sistema entre nesse estado, ele permanecerá assim até ser desativado presencialmente em uma agência bancária.

Simultaneamente, o sistema entra em estado de alerta e inicia a criação de um dossiê, que inclui *logs*, dados de localização e outras informações relevantes. Nesse estágio, a polícia pode ser acionada automaticamente por um sistema, sem a necessidade de intervenção do gerente, como ocorre atualmente.

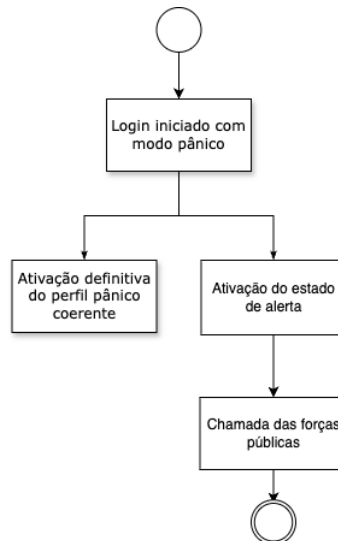


Figura 10: Diagrama de alto nível desde a autenticação do modo pânico até o chamado das forças públicas de segurança.

4.2.4.3 Ativação definitiva do perfil pânico

Na ativação definitiva do perfil pânico coerente, um perfil secundário verossímil com o usuário é mostrado na interface do aplicativo. Nesse perfil são realizadas algumas alterações, dentre elas podemos citar: um saldo mais baixo, sem ou com valores de investimentos bem abaixo dos reais, extrato e histórico de transações de acordo com esse perfil de nova renda, um crédito disponível reduzido de acordo com essa nova renda, aumento da fatura do cartão, PIX limitado de maneira coerente e seguros ofertados de acordo com o perfil.



Figura 11: Alterações principais realizadas no perfil do usuário.

Dentre essas características, algumas deverão ser imputadas pelo usuário, enquanto outras serão automaticamente calculadas pelo banco, utilizando seu sistema, como ocorre atualmente na criação de contas. Por exemplo, imagine um perfil de alta renda, como o de um pequeno empresário que recebe cerca de 60 mil reais por mês, possui investimentos totalizando 1,5 milhão de reais e saldo disponível de 200 mil reais. Esse perfil poderia ser facilmente disfarçado com um perfil que oculta os investimentos, com as mesmas entradas de 60 mil, mas com alto fluxo de saída de capital, seja com cartão, empréstimos, compras etc, o que resultaria num saldo bem abaixo dos 200 mil reais que estariam à mercê dos criminosos. O aumento dos gastos do usuário é a melhor forma de deixar mais verossímil o perfil pânico.

4.2.4.4 Construção do perfil pânico

O perfil pânico deve ser verossímil, mas isso varia consideravelmente de pessoa para pessoa. Uma automatização completa na criação desses perfis poderia comprometer drasticamente a segurança do sistema, pois tornaria evidente que ele está no modo pânico. Além disso, quando o usuário está sob coação, ele pode ser questionado pelos criminosos sobre seus gastos, saldos e investimentos. Se as informações não corresponderem à ordem de grandeza do perfil de pânico, isso aumentaria o risco de identificação da ativação do modo pânico.

Para resolver isso, a proposta é que o próprio usuário defina alguns parâmetros iniciais de sua conta pânico, especialmente relacionados aos seus gastos. Se ele configurar sua

conta pânico com rendimentos semelhantes aos reais, mas com o cartão de crédito no limite, empréstimo consignado realizado, histórico de despesas como pensão alimentícia para filhos e outros gastos, será muito mais plausível que os criminosos acreditem no saldo reduzido que verão nesse modo.

Como pode ser observado no esquema abaixo, a fonte de renda também pode ser escolhida pelo usuário. No entanto, essa escolha deve ser feita de maneira cautelosa e restrita a um público específico. Por exemplo, muitas vezes é possível saber, ou pelo menos estimar, quanto uma pessoa ganha (como no caso de um servidor público, com base na Lei de Transparência), mas é impossível estimar com exatidão quanto essa pessoa gasta.

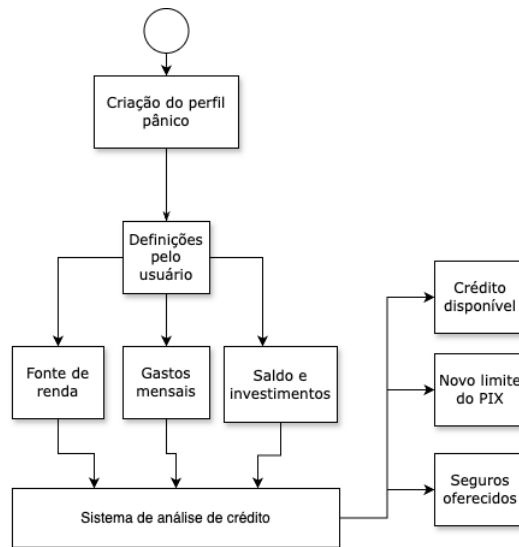


Figura 12: Etapas para a construção do perfil pânico.

Os outros parâmetros serão gerados automaticamente pelo sistema. Em posse dos dados fictícios, o sistema calculará o crédito oferecido para esse cliente, dará um novo limite de PIX diário, os seguros e outros serviços oferecerão outros planos com base no novo perfil.

No final, o sistema contará com três perfis distintos para o usuário: um perfil normal (com os valores reais) e dois perfis de pânico (um com valores abaixo do real e outro ainda mais reduzido). O perfil normal será exibido enquanto o usuário não ativar a senha pânico. Ao utilizar a senha pânico, o sistema entrará no primeiro modo de pânico, bloqueando a conta nesse estado enquanto essa senha for utilizada para acessá-la.

Posteriormente, no caso do usuário alterar para a senha normal, o sistema automaticamente ativará e restará no segundo modo de pânico, exibindo um perfil com valores ainda mais baixos que os anteriores. Esse *modus operandi* faz parte da solução para coibir

que os criminosos forcem a vítima a inserir outra senha além da primeira.

4.2.4.5 Ativação do estado de alerta

Dado a ativação do estado de alerta, o sistema começa a criar um dossiê que será salvo no banco de dados da instituição financeira e só será enviado para a policia após determinação de um *sistema inteligente de identificação do usuário*, que baseado em um sistema de pontuação determinará a probabilidade do usuário não ser o verdadeiro dono da conta acessada.

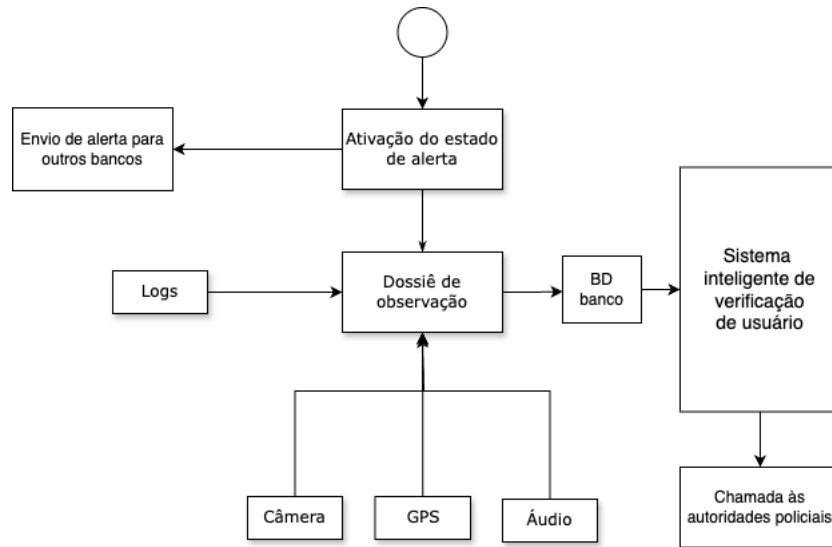


Figura 13: Diagrama que representa em parte o fluxo de dados do estado de alerta até a notificação às autoridades policiais.

Os dados da câmera, do GPS e de áudio serão imediatamente coletados após a ativação do estado de alerta e serão salvos no dossiê. Todos os logs também irão compor esse dossiê.

Os logs indicarão todas as ações dentro do aplicativo (visualização de histórico, de saldo, de empréstimos, realização de PIX etc) realizadas pelo usuário. Esse dossiê será construído continuamente. Ele será salvo no banco de dados do banco e passará por um processo de verificação inteligente da identidade do usuário.

Caso o GPS da vítima seja desativado pelos criminosos, a perda da localização em tempo real será registrada nos logs e contabilizada no sistema de pontos como um aumento significativo no risco ao usuário. O último valor da localização será salvo e incluído no dossiê, pois essa informação pode indicar com precisão o local onde a vítima esteve e provavelmente será perto do local onde ela foi capturada pelos criminosos.

O sistema inteligente receberá todos esses dados para só assim determinar a necessi-

dade ou não do acionamento da polícia. No caso do PIX, ele verificará a localização onde foi feita essa transferência (se o usuário tem o hábito de fazer PIX nessa região), se o destinatário é um destinatário habitual do usuário ou se é de uma conta já visada pelas autoridades policiais, se os valores são condizentes com os habituais pelo usuário.

Com os dados da câmera e do áudio, é possível identificar se o usuário que está manuseando o celular é o verdadeiro titular da conta. Se não for, um alerta de alta probabilidade de fraude será gerado. Caso seja o verdadeiro usuário, a idoneidade da ação ainda não é garantida e o sistema continuará a verificação. A partir do áudio, o sistema pode identificar se há instruções de coerção dirigidas à vítima, se há mais de uma voz presente e como essas vozes interagem no contexto.

Essa etapa é crucial, pois, atualmente, o contato com a polícia não é automático, dependendo do gerente da conta do usuário para acioná-la. Atualmente esse sistema inteligente já existe nas instituições financeiras, ele também funciona com um sistema de pontuação, no entanto, seu uso se limita a pedir mais “confirmações” de autenticidade ao usuário. Em geral, quando se inicia uma série de ações não habituais a pontuação de confiabilidade do usuário cai, e a partir de um limiar, o sistema pede um reforço de senha ou até biometria facial para reforço da confiabilidade. Como já discutido anteriormente, esse tipo de validação de autenticidade não ajuda no caso do sequestro relâmpago, pois a vítima está sob coação dos sequestradores e pode ter suas digitais e rosto usados para a autenticação.

Neste projeto, serão adicionadas ao sistema existente novas entradas que auxiliarão no processo de detecção de um indivíduo sob extorsão. A decisão de acionar a polícia ficará a cargo do sistema. Atualmente, essa responsabilidade é atribuída ao gerente da conta do usuário, o que está sujeito a erros humanos e a um atraso no tempo que pode custar até a vida da vítima.

Meio	Situação	Ação
Câmera	Não identificação biométrica facial.	Aumentar score
	Identificação de objetos perigosos ou suspeitos.	Alertar polícia
	Presença de mais de uma pessoa na cena.	Aumentar score
	Usuário em situação de risco evidente.	Alertar polícia.
Áudio	Escuta-se gritos ou pedidos de socorro.	Alertar polícia
	Presença de palavras ou frases coercitivas.	Alertar polícia
	Mais de uma voz identificada.	Aumentar score

GPS	Localização em área de risco conhecida.	Aumentar score
	Desativação do GPS.	Aumentar score
	Deslocamento rápido e errático do dispositivo.	Aumentar score
	Uso de protocolos de anonimato (e.g., Tor ou VPN).	Aumentar score
Logs	Visualização	
	Visualização de limites de saque e transferência.	Aumentar score
	Visualização de histórico de transações.	Aumentar score
	Visualização de saldo e investimentos.	Aumentar score
	Visualização de crédito disponível.	Aumentar score
	Configurações	
	Alteração de senhas ou e-mail de autenticação.	Aumentar score
	Majoração de limites de saque/transferência.	Aumentar score
	Adição de novo dispositivo à lista de confiáveis.	Aumentar score
	Desativação de autenticação de dois fatores (2FA).	Aumentar score
	Desativação de notificações de segurança por e-mail/SMS.	Aumentar score
	Comportamental	
	Atividade bancária em horários incomuns.	Aumentar score
	Tentativa de acesso simultâneo a múltiplas contas.	Aumentar score
	Acesso ao aplicativo de lugar não usual.	Aumentar score
	Cadência de digitação diferente da usual.	Aumentar score
	Transações	
	Resgate antecipado do fundo de previdência.	Aumentar score
	Resgate antecipado do fundo de garantia.	Aumentar score
	Resgate antecipado de investimentos.	Aumentar score
	Pagamentos de boletos de terceiros de valores elevados.	Aumentar score
	Solicitação de um novo empréstimo ou financiamento.	Aumentar score
	Transferências próximas do limite a novas contas.	Aumentar score

Tabela 3: Meios de coleta de dados, situações e ações tomadas. Saturação da cor indica intensidade da ação.

4.3 Atores

Nesta seção são apresentados os principais atores. Cada ator desempenha um papel específico para garantir o funcionamento seguro e eficiente do sistema, abrangendo desde o

Usuário, que utiliza o aplicativo em situações de risco, até outros agentes responsáveis pela infraestrutura, monitoramento e suporte, como o banco e as autoridades. A especificação de requisitos para cada ator detalha suas responsabilidades, ações esperadas e limitações, estabelecendo um panorama claro para o desenvolvimento e a operação do sistema.

4.3.1 Usuário

O ator usuário representa o indivíduo que interage diretamente com o sistema, seja como cliente de um banco ou como pessoa em situação de risco potencial. Ele é responsável por configurar sua conta no modo pânico, definindo parâmetros como saldo fictício, histórico de transações e outros dados verossímeis.

Durante situações de coerção, o usuário pode ativar o sistema utilizando recursos como uma senha alternativa ou outros mecanismos de emergência. Sua experiência com o aplicativo deve ser intuitiva e segura, priorizando a facilidade de uso para configurações de rotina e respostas rápidas em momentos críticos. A segurança do usuário é o foco principal, garantindo proteção sem comprometer a usabilidade.

4.3.1.1 Dados gerais do usuário

Os dados do usuário podem ser organizados em três categorias principais: informações pessoais, informações bancárias e dados de segurança. Essa categorização facilita a estruturação e o gerenciamento dos parâmetros essenciais para atender aos requisitos do projeto. A tabela abaixo apresenta os parâmetros mapeados para cada categoria, destacando sua relevância e aplicação no contexto do sistema.

Informações pessoais	Informações bancárias	Informações de segurança
Nome	Agência	Biometria
Idade	Conta	Senha no modo normal
Celular	Banco	Senha no modo pânico
E-mail	Saldo bancário	Senha para transferências
CEP	Fatura atual	
	Limite de crédito	
	Empréstimo	
	Histórico de transações	

Tabela 4: Dados gerais do usuário.

As informações pessoais englobam os principais dados de identificação do indivíduo, sendo essenciais para processos como a abertura de contas bancárias e a associação de perfis ao sistema. Esses dados servem como base para garantir a autenticidade e a vinculação adequada do usuário ao serviço.

As informações bancárias abrangem elementos como saldo disponível, histórico de transações e limites de crédito. Esses dados financeiros são fundamentais para a gestão da conta e o monitoramento das atividades do usuário, oferecendo uma visão de sua situação financeira e comportamentos de consumo.

Por fim, os dados de segurança incluem elementos como senhas e chaves criptográficas, desempenhando um papel central na autenticação do usuário e na proteção contra acessos não autorizados. Esses dados são projetados para garantir a segurança e a integridade das interações com o sistema.

4.3.1.2 Exemplos fictícios

Para garantir a funcionalidade do modo pânico, é essencial que o aplicativo gere exemplos fictícios de transações, extratos e saldos que simulem atividades financeiras reais. Esses exemplos serão projetados para refletir o perfil típico de gastos do usuário, mas com ajustes que incluam um aumento de despesas e dívidas simuladas, de forma a justificar saldos menores e tornar o perfil mais verossímil durante situações de coação.

As tabelas abaixo fornecem as informações de um usuário fictício do banco.

Informações Pessoais	Valores
Nome	Maria Silva
Idade	32 anos
Celular	(11) 91234-5678
E-mail	maria.silva@gmail.com
CEP	12345-678

Tabela 5: Dados pessoais.

Informações Bancárias	Valores
Agência	0001
Conta	5123423-0
Banco	0310
Saldo bancário	R\$ 23.250,00
Fatura atual	R\$ 4.450,00
Limite de crédito	R\$ 5.000,00
Limite de empréstimo	R\$ 15.000,00
Histórico de transações	- 10/Dez: Mercado, - R\$ 150,00 - 12/Dez: Transferência, - R\$ 200,00 - 18/Dez: Depósito, + R\$ 500,00

Tabela 6: Dados bancários.

Informações de Segurança	Valores
Biometria	Impressão digital
Senha no modo normal	812934
Senha no modo pânico	123456
Senha para transferências	21473813

Tabela 7: Dados de segurança.

4.3.1.3 Usuário no modo pânico

No modo pânico, o sistema deve alterar apenas os dados bancários do usuário para simular um perfil financeiro mais restrito. O crédito apresentado no aplicativo será reduzido, limitando a capacidade de realizar grandes transações ou saques e será adicionado novos gastos e dívidas ao usuário, justificando assim um saldo menor e limites de crédito abaixo dos reais.

Informações Bancárias	Valores no modo pânico
Agência	0001
Conta	5123423-0
Banco	0310
Saldo bancário	R\$ 3.250,00
Fatura atual	R\$ 2.450,00
Limite de crédito	R\$ 1.000,00
Limite de empréstimo	R\$ 3.000,00
Histórico de transações	- 10/Dez: Compra, - R\$ 150,00 - 12/Dez: Transferência, - R\$ 200,00 - 14/Dez: Consignado, - R\$ 1000,00 - 16/Dez: Pensão, - R\$ 1500,00 - 17/Dez: Aluguel, - R\$ 2000,00 - 17/Dez: Carro, - R\$ 750,00 - 18/Dez: Depósito, + R\$ 500,00

Tabela 8: Dados bancários no modo pânico. Dados em vermelho correspondem a valores fictícios adicionados.

4.3.2 Instituições financeiras

A comunicação do banco com o dispositivo móvel no modo pânico será aumentada. Todas as situações presentes na tabela 3 serão reportadas e guardadas do lado do servidor bancário. Para isso, a comunicação precisa utilizar protocolos seguros para garantir que todos os dados sejam transmitidos de forma criptografada, evitando interceptações e ataques durante a transmissão.

A garantia da confidencialidade desses envios é essencial para assegurar a negação plausível da vítima diante do criminoso. Se o criminoso conseguir interceptar os dados e descobrir que está sendo monitorado, quebra-se a possibilidade da vítima negar que ativou o modo pânico.

A camada de sessão lida com a autenticação e a gestão dos dados do usuário em tempo real. É importante que, no modo pânico, o sistema consiga diferenciar as sessões, oferecer um conjunto de dados fictício ao criminoso, sem comprometer a integridade dos dados reais do usuário, além de transmitir os dados de monitoramento para o servidor do banco.

Mais especificamente, é essencial garantir que toda a comunicação esteja protegida

contra ataques de *downgrade*, o que torna a escolha dos protocolos fundamental. O uso obrigatório do TLS 1.3 é crucial para evitar vulnerabilidades já conhecidas, sendo igualmente importante monitorar de forma contínua a aplicação correta e atualização dos protocolos mais seguros.

4.3.2.1 Autenticação do usuário

A autenticação do usuário pode ser feita utilizando múltiplos fatores. No caso do modo pânico, o usuário poderá inserir uma senha alternativa que ativa o modo pânico ou ainda qualquer dos métodos já mencionados. A autenticidade dessas informações será garantida por meio de verificações contínuas durante a sessão, sem interferir na usabilidade do sistema.

4.3.2.2 Modo pânico

No modo pânico, o sistema entra em uma sessão especial onde todos os dados apresentados ao usuário e ao sequestrador são fictícios. Os bancos permitem transações, mas os valores reais permanecem ocultos. O sistema utiliza técnicas de obfuscação para garantir que o sequestrador não consiga detectar a ativação do modo pânico.

4.3.2.3 Comunicação com autoridades

Caso o sistema identifique atividades suspeitas durante o modo pânico (como tentativas de saques em locais incomuns ou comportamentos coercitivos), ele pode enviar um alerta silencioso às autoridades, fornecendo a localização e outras informações relevantes para uma possível intervenção. Esta comunicação será feita de forma automática pelo sistema do banco, sem que os criminosos percebam.

4.3.3 Autoridades policiais

Atualmente a polícia afirma ter uma linha direta com os bancos em que em caso de notificação, eles agem imediatamente. Com a solução pânico em ação, o sistema bancário irá enviar um dossiê à polícia quando ele decidir que o seu usuário está sob perigo. Esse dossiê não existe atualmente e a sua criação pode ajudar a atividade policial em si.

4.3.3.1 Software policial

O software policial deve ser capaz de receber o dossiê completo da vítima e as informações do seu celular. Esse sistema permitirá, de forma confidencial, estabelecer uma linha direta entre a polícia e o sistema bancário.

Ele precisa ser interoperável com todos os bancos, além de ser de fácil acesso e leitura, garantindo que os agentes policiais compreendam rapidamente a situação do usuário. Isso possibilitará uma intervenção policial ágil e eficaz, quando necessário.

4.3.4 Seguradoras

As seguradoras possuem um papel essencial na construção da solução pânico. Ela é uma parte interessada diretamente envolvida conjuntamente com os bancos.

4.3.4.1 Modelo de negócios

A solução pânico é uma solução financeiramente muito rentável para as seguradoras, pois pode-se ofertar seguros no momento da criação do perfil pânico pelo usuário. Além de que, com a mitigação dos valores roubados, as seguradoras terão menor valor para reembolsar as vítimas que contrataram seus serviços.

Além dessas vantagens, as seguradoras já possuem experiência no gerenciamento de dados estatísticos dos clientes, o que poderia facilitar o processo de criação do perfil pânico. Por isso, elas devem desempenhar um papel ativo e de liderança na implementação dessa solução de segurança.

5 DESENVOLVIMENTO DO TRABALHO

Alguns artefatos utilizados em gerenciamento de projetos foram utilizados nesse trabalho para auxiliar na organização, na metodologia e desenvolvimento. Esses artefatos são métodos consolidados que embasam as soluções propostas nesse projeto.

5.1 Análise das partes interessadas

Primeiramente foi identificadas as partes interessadas, são elas: as instituições financeiras, as seguradoras, clientes de médio e alto capital financeiro, órgãos da segurança pública e os criminosos.

5.1.1 Registro das partes interessadas

O registro das partes interessadas é um documento que contém informações sobre as partes interessadas já identificadas do projeto. Esse registro trata de avaliar o nível de engajamento e a classificação das partes interessadas, definir o nível de interesse, poder e influência, como essas partes participam ou vão influenciar o andamento da solução proposta.

5.1.1.1 Instituições financeiras

As instituições financeiras, em particular os bancos, estão diretamente envolvidos, pois são atores que estão perdendo ativos financeiros com os sequestros relâmpagos e estão diretamente envolvidos na implementação das soluções propostas nesse trabalho.

Por ter influência sobre as políticas de segurança financeira, eles são os únicos que podem fornecer suporte em termos de integração de sistemas, monitoramento de transações suspeitas e notificação em tempo real para prevenir ou mitigar o impacto de um sequestro.

Hoje eles ocupam o nível de engajamento de conscientes do problema, mas precisa alcançar o nível de engajamento de líderes desse projeto.

5.1.1.2 Seguradoras

As seguradoras muitas vezes estão integradas aos bancos, no entanto, a importância do seu engajamento é alta e precisa ser destacada. Há um espaço de mercado enorme para as seguradoras expandirem seu modelo de negócios nesse projeto.

A oferta de um seguro contra sequestro relâmpago entra no seu modelo de negócios e ainda fornece uma ideia de segurança para o cliente de seus ativos roubados. O oferecimento de um seguro para o cliente no momento em que ele cria seu perfil pânico é uma parte essencial desse projeto. Além disso, quanto menor o valor subtraído pela vítima, menor será o valor a restituir por parte da seguradora.

Outro ponto importante é a base de dados que as seguradoras possuem, essa base de dados pode auxiliar na criação de perfis pânicos verossímeis aos usuários que contratam seus seguros.

O engajamento das seguradoras hoje é neutro, mas deve mudar o status para, no mínimo, Apoiadores. Idealmente o status de Líderes juntamente com os bancos alavancaria o projeto.

5.1.1.3 Usuários (vítimas potenciais)

Essa parte interessada são as possíveis vítimas, que buscam segurança e maneiras de reduzir os riscos de perda de seus ativos durante o sequestro. Elas desempenham um papel crucial em todas as etapas do processo. Será necessário que participem ativamente na adaptação do modo pânico, o que requer um processo de educação para que compreendam completamente o funcionamento de todo o sistema.

Esses usuários são usuários de média e alta renda. Eles possuem receio de perder seus ativos durante esse tipo de crime e geralmente eles possuem alta escolaridade, em geral, possuem capacidade intelectual e cognitiva para entender todo o processo da solução pânico e de aceitar conscientemente os riscos e oportunidades oferecidas por essa solução.

Atualmente eles estão no nível de engajamento desinformados e precisam passar para o nível de apoiadores.

5.1.1.4 Órgãos de segurança pública

As autoridades policiais são fundamentais na resposta a incidentes criminosos, desempenhando um papel chave no monitoramento e na intervenção rápida durante um sequestro. Elas também são essenciais no processo de implementação do projeto, pois a automatização do chamado policial depende do desenvolvimento de uma solução de software do lado deles para receber esses chamados.

No entanto, ao conversamos com integrantes da instituição, sentimos uma enorme resistência de mudança no processo como ele é feito hoje. Outro ponto é a resistência com a ideia do modo pânico ter um “pouco” de dinheiro, eles se mostraram bastante inflexíveis com esse “ganho” por parte dos criminosos.

O nível de engajamento dos policiais hoje é resistente e precisa passar para o status de apoiadores.

5.1.1.5 Criminosos

Os criminosos são partes envolvidas diretas no ato criminoso. É preciso analisar todas suas ações para o melhor detalhamento do processo de solução pânico.

Atualmente o nível de engajamento dos criminosos é desinformados, mas com o modo pânico em atividade eles passarão a ser resistentes, pois buscarão modos de burlar a solução e auferir maiores ganhos pelo ato criminoso. Entender como eles agem hoje e como irão reagir à solução é essencial para uma maior efetividade do projeto.

Matriz de avaliação do nível de engajamento das partes interessadas

É a matriz que compara os níveis de engajamento atual e desejado das partes interessadas, para que seja possível definir uma estratégia adequada do nível de engajamento de cada parte interessada do projeto.

Parte Interessada	Nível Atual	Nível Desejado
Instituições Financeiras	Conscientes	Líderes
Seguradoras	Neutro	Apoiadores/Líderes
Usuários	Desinformados	Apoiadores
Órgãos de Segurança Pública	Resistentes	Apoiadores
Criminosos	Desinformados	Resistentes

Tabela 9: Matriz de Engajamento das Partes Interessadas

Monitoramento e comunicação com as partes interessadas

O monitoramento de todas as partes envolvidas no projeto é essencial para alcançar o sucesso planejado do projeto. Se os bancos e seguradoras não tomarem a voz ativa de liderança, ficará muito difícil a implementação real dessa solução. Mostrar as vantagens econômicas aos clientes é uma forma de engajar as partes interessadas no projeto e pressionar os bancos e seguradoras pela implementação da solução.

A comunicação eficaz e eficiente serão essenciais nesse projeto, ela precisará ser feita com base numa estratégia adequada para a elevação do nível de engajamento de cada parte interessada do projeto. A estratégia será importante, pois como temos partes interessadas bem distintas, precisará de uma adaptabilidade comunicativa com cada parte envolvida.

5.2 Matriz RACI

A matriz de responsabilidades (também conhecida como matriz RACI) é um artefato de informação visual importante na atribuição de responsabilidades em um projeto. A interação harmônica entre as partes interessadas é essencial para o sucesso do projeto e isso passa pela clareza da responsabilidade de cada um.

Usualmente ela é feita para atribuir responsabilidades aos atores (gerentes, desenvolvedores entre outros) dentro de um projeto. Neste projeto a matriz RACI é usada para atribuir responsabilidades às partes interessadas. É importante definir quem tem a responsabilidade pela execução (R), responsabilidade pela aprovação/decisão (A), quem será consultado (C) e quem será apenas informado (I), para o caso de nenhuma ação será indicado com o hífen (-).

Em geral, a matriz RACI tem ao menos um responsável para cada atividade e exclusivamente um aprovador para cada tarefa. No entanto, aqui usaremos mais a ideia de alocar responsabilidades e forçar a interação entre as partes interessadas, descartando assim essas obrigações que existem normalmente num gerenciamento de projetos.

Por exemplo, a atividade de criação do perfil pânico, ela é de responsabilidade da Instituição Financeira e dos Usuários, no entanto, é de total interesse das Seguradoras que nessa criação seja ofertado um seguro para os ativos financeiros possivelmente roubados, ou ainda uma oferta de seguro de vida, portanto, ela apesar de não responsável é de boa prática que as seguradoras sejam consultadas para ajudarem na criação desse formulário de criação do perfil pânico pelo usuário. As seguradoras podem ajudar de qual maneira o banco vai oferecer esses pacotes de seguro, como deve ser feito o formulário e em qual

momento deve ser ofertado.

Atividade / Parte Interessada	Instituições Financeiras	Seguradoras	Usuários	Órgãos de Segurança Pública
Definição da política de score	R	I	I	C
Mudança na política de criação de contas já existentes	R	I	I	I
Alteração na autenticação do app bancário	R	I	C	I
Criação de token bancário	R	I	I	I
Mudança dos valores dos atributos no modo pânico	R	R	R	I
Criação do sistema inteligente de verificação do usuário	R	I	I	C
Criação do perfil pânico	R	C	R	-
Desenvolvimento de um sistema para recepção automática de chamados	C	I	I	R

Tabela 10: Matriz responsabilidade das Partes Interessadas

5.3 Matriz SWOT

A análise SWOT fornece subsídios para análise de forças (S), fraquezas (W), oportunidades (O) e ameaças (T), com a finalidade de identificar riscos. As ameaças e fraquezas são riscos negativos, as forças e oportunidades riscos positivos. Em geral, as forças e fraquezas estão relacionadas a algo interno e as oportunidades e ameaças a algo externo.

Forças (Strengths)	Fraquezas (Weaknesses)
Sistema inteligente com monitoramento contínuo e contato automatizado das autoridades policiais.	Dependência da precisão do sistema de detecção para evitar falhas de segurança.
Implementação de múltiplos tipos de autenticação segundo perfil do usuário.	Vulnerabilidade a falhas humanas, como senhas esquecidas ou utilizadas de forma inadequada.
Modo pânico com forte proteção contra a descoberta e uso indevido.	Potencial sobrecarga de chamadas de emergência em caso de falso positivo.
Oportunidades (Opportunities)	Ameaças (Threats)
Avanço das tecnologias de IA que podem melhorar a detecção e minimização de riscos.	Falhas técnicas no sistema que podem comprometer a segurança e permitir ação criminosa.
Ampla modelo de negócio para banco e seguradoras	Engenharia social que pode comprometer o acesso à autenticação pânico por manipulação do usuário.
Aumento da segurança para a sociedade	Riscos de escalada da violência ou extorsão caso os criminosos descubram o uso do modo pânico.

Tabela 11: Matriz SWOT para identificação de riscos.

5.4 Análise de riscos

Antes de validar as soluções, é necessário realizar uma análise dos riscos envolvidos nesse processo. Os ativos mais importantes deste projeto são a integridade física do usuário, a preservação de sua vida e seus ativos financeiros. A solução de ocultação do aplicativo e a solução de pânico geram riscos secundários que precisam ser analisados e tratados continuamente até sua aceitação.

5.4.1 Modo pânico

Com base na matriz SWOT realizada, faremos uma análise de risco para os riscos **negativos** envolvidos na solução pânico.

5.4.1.1 Riscos de falso positivo

1) Risco do usuário entrar com a senha fraca alternativa sem estar numa situação de perigo. O risco de falso positivo poderia sobrecarregar as forças policiais se essas fossem chamadas logo após a senha fraca alternativa. No entanto, o sistema inteligente usará essa entrada apenas como uma das variáveis a ser levada em conta para o chamado policial. Esse risco tem impacto baixo e probabilidade alta.

Solução: **mitigar risco** de sobrecarga do chamado policial. Só a senha fraca alternativa não é motivo suficiente para chamar as autoridades de segurança pública. O modo pânico é ativado, e um dossiê começa a ser gerado. Caso a confirmação seja feita por meio de uma segunda senha forte alternativa, a polícia é acionada e recebe essas informações imediatamente.

5.4.1.2 Riscos de falso negativo

2) Risco do usuário entrar com a senha fraca original estando em situação de perigo. Esse é o risco de falso negativo. Essa situação é a mais perigosa, pois caso o usuário “esqueça” sua senha pânico e entre com a senha original, o sistema irá mostrar o valor verdadeiro de seus ativos financeiros e consequentemente eles estarão à visão dos criminosos.

Nesse modo, outros fatores continuam sendo monitorados continuamente pelo sistema inteligente que pode por si só desconfiar que não é o usuário verdadeiro que está em posse do seu celular, ele poderá pedir biometria e outros fatores de autenticação para evitar acesso de terceiro sem a presença do usuário verdadeiro (como já acontece atualmente).

No entanto, em casos de sequestro e extorsão, será necessário aguardar que o usuário insira a senha forte alternativa durante a transferência para acionar as autoridades policiais. Vale ressaltar que, nessa situação específica, o perfil pânico não pode ser ativado, pois os ativos financeiros do usuário já foram expostos aos criminosos. Contudo, isso não dispensa o sistema inteligente de monitorar o usuário, analisando sua câmera, sons e outros fatores, a fim de, em conjunto com outras informações, determinar a necessidade de acionar a polícia e preservar a integridade física do usuário. Esse risco apresenta um

impacto alto e uma probabilidade média.

Solução: **mitigar risco** e suas consequências. O perfil pânico não é ativado, mas, caso a transferência seja confirmada como resultado de extorsão, a polícia deve ser contatada automaticamente. Além disso, é crucial tomar medidas para minimizar os danos da extorsão, considerando que a vítima ainda está sob custódia dos criminosos, os quais podem tentar cometer outros crimes contra ela.

Matriz de confusão

Essas classificações serão realizadas pelo sistema inteligente que utilizará técnicas de IA que fogem do escopo desse projeto, mas vale destacar que será necessário criar o que se chama de Matriz de confusão (também chamada de matriz de erros) que metrifica os falsos positivos (erro do tipo I) e falsos negativos (erro do tipo II) em relação com os verdadeiros positivos e negativos.

Essa técnica envolve a determinação de parâmetros como acurácia, precisão, *recall*, especificidade e *F-score*. Para o escopo deste projeto, o importante é destacar que o falso positivo tem baixo impacto nos ativos, enquanto que o falso negativo tem alto impacto em todos os ativos (vida e recursos financeiros). Por isso, devem ser usadas técnicas que reduzem ao máximo os falsos negativos.

		Predito	
		Condição positiva prevista	Condição negativa prevista
Verdade	Positivo	Verdadeiro Positivo	Falso Negativo (Erro Tipo II)
	Negativo	Falso Positivo (Erro Tipo I)	Verdadeiro Negativo

Tabela 12: Matriz de confusão (ou matriz de erro). Visualização para resultados de algoritmo classificador.

5.4.1.3 Riscos sobre o modo pânico

3) Risco de desconfiança dos criminosos que o usuário entrou em modo pânico.

Solução: **aceitar risco**. Mesmo que os criminosos desconfiem que está entrando no modo pânico da conta do usuário, ele nunca poderá ter certeza disso, pois há uma similaridade dos perfis normal e pânico e uma verosimilhança da conta pânico com a vida do usuário. Esse risco tem impacto baixo e probabilidade média.

4) Risco de descoberta que o usuário possui uma conta em modo pânico.

Solução: **aceitar risco**. Mesmo que o criminoso saiba antecipadamente que o usuário possui uma conta que possui o modo pânico, ele não poderá saber se a senha colocada pelo usuário vai entrar na conta em seu modo normal ou no seu modo pânico, tendo que se contentar com o valor que terá na conta após entrada. Esse risco tem impacto baixo e probabilidade baixa.

5) Risco de descoberta que o usuário entrou no modo pânico.

Solução: **aceitar risco**. Mesmo que os criminosos de algum modo descubram que o usuário entrou na conta no modo pânico e obriguem o usuário a colocar a senha original correta, a conta uma vez ativada no modo pânico não poderá voltar ao modo normal sem que o usuário passe numa agência física, onde ele mudará a senha original e senha alternativa.

A conta está bloqueada nesse estado, evitando mais extorsões. No entanto, esse risco tem um impacto médio, pois pode escalar em violência se os criminosos quiserem se vingar do usuário que não entrou na conta original, mas tem probabilidade baixa, pois o projeto em si é baseado em que o modo pânico seja indistinguível do modo real.

5.4.1.4 Riscos de falhas no sistema

6) Risco de falha técnica no sistema inteligente

Esse risco envolve a possibilidade de o sistema não funcionar corretamente em momentos críticos devido a falhas técnicas, como indisponibilidade de servidores, erros na detecção de situações de perigo, quedas de conexão ou *bugs* inesperados no software. Essas situações podem comprometer a segurança do usuário, uma vez que o sistema pode não conseguir identificar uma situação de risco ou realizar as ações necessárias, como chamar as autoridades ou bloquear a conta no modo pânico.

Apesar de ter probabilidade baixa, considerando que o sistema deve ser projetado para alta disponibilidade e redundância, o impacto de uma falha desse tipo é alto, pois coloca em risco a integridade física e os ativos financeiros do usuário.

Solução: **aceitar risco**. Ainda na fase de projeto, serão implementadas soluções para que a probabilidade desse risco seja baixa, podemos citar: implementar infraestrutura redundante, mecanismos de *failover* e monitoramento constante para identificar e resolver problemas rapidamente. Dada a disponibilidade como de alta importância, resta aceitar o risco.

Matriz de Probabilidade e Impacto

A matriz de probabilidade e impacto é um artefato de análise qualitativa. O foco é a priorização dos riscos. Por exemplo: o risco 6, antes de ser colocado no projeto que cabe um sistema de alta disponibilidade para o sistema inteligente, a probabilidade dele era média com alto impacto, para reduzir isso, o risco foi **mitigado** colocando no projeto um sistema de alta disponibilidade, levando o risco 6 para uma escala de baixa probabilidade, o que culminou com a **aceitação** desse risco.

Essa matriz deve ser revista periodicamente, com o objetivo de reduzir constantemente a probabilidade e o impacto dos riscos associados. Com o surgimento de novas tecnologias e ideias, surgem também novas soluções que podem mitigar riscos, mas, por outro lado, muitos outros riscos podem emergir e devem ser catalogados e analisados minuciosamente.

Probabilidade/ Impacto	Baixo	Médio	Alto
Alta	Risco 1		
Média	Risco 3	Risco 5	Risco 2
Baixa	Risco 4		Risco 6

Tabela 13: Matriz de Probabilidade e Impacto

6 CONSIDERAÇÕES FINAIS

As considerações finais deste projeto destacam o cumprimento dos objetivos estabelecidos e apontam direções para expansões futuras, com foco na integração de inteligência artificial e na avaliação da usabilidade do sistema.

O primeiro objetivo foi cumprido com o mapeamento detalhado dos aplicativos bancários atuais e das soluções propostas por BACEN, Febraban e instituições financeiras como NuBank e PicPay. Essas soluções, que incluem a limitação do PIX e o uso de áreas seguras baseadas em Wi-Fi e localização, foram analisadas e consideradas insuficientes para mitigar os danos causados por sequestros relâmpago. Além do mais, acreditamos que a limitação do PIX pode ser contraproducente, aumentando o tempo de sequestro.

O segundo objetivo, relacionado à identificação de problemas no fluxo atual, também foi atingido. O processo revelou que o uso do gerente como intermediador no acionamento de órgãos policiais constitui um gargalo significativo, exigindo a criação de uma automatização para agilizar esse processo e torná-lo mais eficaz.

O terceiro objetivo foi alcançado com a definição dos ativos do projeto, que incluem a integridade física do usuário e a preservação de seus ativos financeiros. Diversas soluções foram desenvolvidas para mitigar danos a esses ativos, como a ocultação de dispositivo, autenticação multifator e, principalmente, o modo pânico, cuja implementação foi detalhada no projeto.

O quarto objetivo foi cumprido com a criação de artefatos que suportaram a análise de riscos. As partes interessadas foram identificadas e suas responsabilidades atribuídas com o uso da matriz RACI. Além disso, a análise de forças e fraquezas do projeto foi conduzida com a matriz SWOT, fornecendo uma base sólida para o processo iterativo de análise e tratamento de riscos, até alcançar um nível de aceitação satisfatório.

No que diz respeito à expansão futura, o uso de inteligência artificial apresenta grande potencial para aprimorar o sistema. A IA pode ser empregada para comparar perfis de uso em estado normal e de pânico, calculando a credibilidade de inconsistências detectadas e

aumentando a precisão das respostas. As seguradoras, com seus vastos bancos de dados de perfis comportamentais, podem colaborar no treinamento do sistema, ampliando sua eficácia. Além disso, a IA pode ser utilizada para melhorar o acionamento de órgãos de segurança, reduzindo falsos negativos ao atribuir pesos quantitativos a diferentes ações críticas.

Quanto à usabilidade, será fundamental realizar testes com protótipos que simulem as funcionalidades do sistema. Esses testes permitirão avaliar diferentes métodos de autenticação e sua adesão pelos usuários, bem como identificar o equilíbrio entre a perda de segurança aceitável e a usabilidade do sistema. A mensuração desses fatores será essencial para garantir que o sistema seja funcional, seguro e amplamente adotado.

REFERÊNCIAS BIBLIOGRÁFICAS

- [1] O Fluminense, Jornal do Estado do Rio. *O Fluminense*, Ano 120(35069), December 1997. Edição de 19 de dezembro de 1997.
- [2] Secretaria de Segurança Pública do Estado de São Paulo. Dados Trimestrais - Estatísticas de Criminalidade, 2024. URL <https://www.ssp.sp.gov.br/estatistica/dados-trimestrais>. Acesso em: 29 nov. 2024.
- [3] Biblioteca Nacional. Bndigital, 2024. URL <https://memoria.bn.gov.br/hdb/periodico.aspx>. Plataforma de periódicos históricos digitalizados pela Biblioteca Nacional do Brasil.
- [4] Senado Federal. Complemento 2 - Documentos Históricos, 2024. URL https://www2.senado.leg.br/bdsf/bitstream/handle/id/316287/complemento_2.htm?sequence=3&isAllowed=y. Acesso em: 29 nov. 2024.
- [5] Pandemia acelera bancarização e transforma setor de meios de pagamento. *Febrabantech*, 2023. URL <https://febrabantech.febraban.org.br/temas/meios-de-pagamento/pandemia-acelera-bancarizacao-e-transforma-setor-de-meios-de-pagamento>. Acessado em: 29 Mar. 2024.
- [6] Mp e febraban discutem como combater uso do pix em sequestros relâmpagos. *InfoMoney*, março 2023. URL <https://www.infomoney.com.br/minhas-financas/mp-e-febraban-discutem-como-combater-uso-do-pix-em-sequestros-relampagos/>. Acessado em: 29 Mar. 2024.
- [7] Banco Central do Brasil. Pix - serão atualizadas as regras de segurança para novos dispositivos cadastrados, 2024. URL <https://www.bcb.gov.br/detalhenoticia/20390/noticia>. Acesso em: 29 nov. 2024.
- [8] Diferentes senhas no banco do brasil. *Site Banco do Brasil*, 2024. URL <https://www.bb.com.br/site/setor-publico/seguranca/senhas/>. Acessado em: 29 Mar. 2024.

- [9] Biometria facial: utilização por instituições financeiras na prevenção a fraudes. *Febrabantech*, 2023. URL <https://febrabantech.febraban.org.br/especialista/patricia-peck-pinheiro/biometria-facial-utilizacao-por-instituicoes-financeiras-na-prevencao-a-fraudes>. Acessado em: 29 Mar. 2024.
- [10] Nubank. Nubank lança modo rua, função inovadora de segurança que limita transações no app ao sair de casa, 2022. URL <https://international.nubank.com.br/pt-br/consumidores/nubank-lanca-modo-rua-funcao-inovadora-de-seguranca-que-limita-transacoes-no-a>. Acessado em 21 nov. 2024.
- [11] Blog PicPay. Picpay lança modo seguro que aumenta proteção dos usuários, 2024. URL <https://meajuda.picpay.com/hc/pt-br/articles/26808643828243-Qual-a-diferen%C3%A7a-entre-os-tipos-de-prote%C3%A7%C3%A3o-saldos-protegidos-e-saldos-invis%C3%ADveis>. Acessado em 21 nov. 2024.
- [12] ZDNet. Best apps to hide apps and protect your privacy. 2024. URL <https://www.zdnet.com>.
- [13] GPS Brasília. Regras do pix mudam a partir desta sexta-feira (1º), 2024. URL <https://gpsbrasil.com.br/regras-do-pix-mudam-a-partir-desta-sexta-feira-1o/>. Accessed: 2024-11-22.
- [14] William Stallings and Lawrie Brown. *Computer Security: Principles and Practice*. Pearson, 2nd edition, 2011.
- [15] R. Shirey. Internet Security Glossary. Request for Comments 2828, Internet Engineering Task Force (IETF), May 2000. URL <https://datatracker.ietf.org/doc/rfc2828/>.
- [16] William Stallings and Lawrie Brown. *Computer Security: Principles and Practice*. Pearson, Boston, 3rd edition, 2015.
- [17] Chen Chen, Anrin Chakraborti, and Radu Sion. INFUSE: Invisible plausibly-deniable file system for NAND flash. *Proceedings on Privacy Enhancing Technologies*, pages 239–254, 2020. doi: 10.2478/popets-2020-0071.

- [18] Angela Whitten and Jeffrey D. Tygar. Why johnny can't encrypt: A usability evaluation of pgp 5.0. In *Proceedings of the 8th USENIX Security Symposium*, 1999.
- [19] Com pix, número de sequestros no estado de sp bate recorde em 15 anos. *UOL Notícias*, janeiro 2023. URL <https://noticias.uol.com.br/ultimas-noticias/agencia-estado/2023/01/17/com-pix-numero-de-sequestros-no-estado-de-sp-bate-recorde-em-15-anos.htm>. Acessado em: 29 Mar. 2024.
- [20] Marcus Vinicius de Viveiro Dias. Enquadramento típico do chamado "sequestro-relâmpago". *Rev. Minist Público, Rio de Janeiro, RJ*, 2005. URL https://www.mprj.mp.br/documents/20184/2779433/Marcus_Vinicius_de_Viveiros_Dias.pdf. Acessado em: 29 Mar. 2024.
- [21] Esther Kimberly Rodrigues do Nascimento. Percepção dos usuários do mobile banking: confiabilidade, segurança, facilidade e intenções de uso. B.S. thesis, 2023. URL <https://repositorio.ifpb.edu.br/bitstream/177683/2683/1/PERCEP%C3%87%C3%83O%20DOS%20USU%C3%81RIOS%20DO%20MOBILE%20BANKING-confiabilidade%2C%20seguran%C3%A7a%2C%20facilidade%20e%20inten%C3%A7%C3%B5es%20de%20uso.pdf>. Acessado em: 29 Mar. 2024.
- [22] Frederic de Mariz. How will the 2020 crisis accelerate the evolution of the banking system? In *Financial Transformations Beyond the COVID-19 Health Crisis*, pages 667–695. World Scientific, 2022. URL <https://dl.acm.org/doi/abs/10.1145/3002170>. Acessado em: 29 Mar. 2024.
- [23] Malik Mustafa. Mobile banking app development and implementation. 2021. URL https://www.researchgate.net/profile/Editor-Ijmtst/publication/356775326_Mobile_Banking_App_Development_and_Implementation/links/61ab0a5650e22929cd452751/Mobile-Banking-App-Development-and-Implementation.pdf. Acessado em: 29 Mar. 2024.
- [24] Cristian Ciurea. The development of a mobile application in a collaborative banking system. *Informatica Economica*, 14(3), 2010. URL <https://www.revistaie.ase.ro/content/55/1007%20-%20Ciurea.pdf>. Acessado em: 29 Mar. 2024.
- [25] Shilpa Shaju and V Panchami. Bisc authentication algorithm: An efficient new authentication algorithm using three factor authentication for mobile banking. In

- 2016 Online International Conference on Green Engineering and Technologies (IC-GET)*, pages 1–5. IEEE, 2016. URL <https://ieeexplore.ieee.org/abstract/document/7916852>. Acessado em: 29 Mar. 2024.
- [26] Özlem Durmaz Incel, Seçil Günay, Yasemin Akan, Yunus Barlas, Okan Engin Basar, Gülfem Isiklar Alptekin, and Mustafa Isbilen. Dakota: sensor and touch screen-based continuous authentication on a mobile banking application. *IEEE Access*, 9:38943–38960, 2021. URL <https://ieeexplore.ieee.org/abstract/document/9367144>. Acessado em: 29 Mar. 2024.
- [27] JN Ndunagu and UJ Nwoduh. Development of an enhanced mobile banking security: multifactor authentication approach. *Electroscope Journal*, 10:33–42, 2019. URL <https://electroscopejournal.org.ng/index.php/ej/article/view/11/11>. Acessado em: 29 Mar. 2024.
- [28] Nilay Yıldırım and Asaf Varol. Android based mobile application development for web login authentication using fingerprint recognition feature. In *2015 23rd Signal Processing and Communications Applications Conference (SIU)*, pages 2662–2665. IEEE, 2015. URL <https://ieeexplore.ieee.org/abstract/document/7130436>. Acessado em: 29 Mar. 2024.
- [29] Busalire Onesmus Emeka and Shaoying Liu. Security requirement engineering using structured object-oriented formal language for m-banking applications. In *2017 IEEE International Conference on Software Quality, Reliability and Security (QRS)*, pages 176–183. IEEE, 2017. URL <https://ieeexplore.ieee.org/abstract/document/8009921>. Acessado em: 29 Mar. 2024.
- [30] Harleen K Flora and Swati V Chande. A review and anaysis on mobile application development processes using agile methodologies. *International Journal of Research in Computer Science*, 3(4):9, 2013. URL https://d1wqtxts1xzle7.cloudfront.net/34567478/1._Review_and_Analysis_on_Mobile_Application_development_Processes_Using_Agile_Methodologies-libre.pdf?1409298590=&response-content-disposition=inline%3B+filename%3DA_Review_and_Analysis_of_Existing_Agile.pdf&Expires=1711675450&Signature=WnxUOXnfbgCsjcDq5r5tq504bWjdBy5RFHa-ucmzxYEAXQ4zmzAZZmajf2QWELERCM-7CwQc~nVpifb._&Key-Pair-Id=APKAJLOHF5GGSLRBV4ZA. Acessado em: 29 Mar. 2024.
- [31] Neymis Misiko Jacob. A review of mobile application development in the agile software development environment. *Global Journal of Computer Science and Technology*,

19(C1):19–22, 2019. URL <https://gjcst.com/index.php/gjcst/article/view/447/441>. Acessado em: 29 Mar. 2024.

- [32] Vincent Bindschaedler, Reza Shokri, and Carl A Gunter. Plausible deniability for privacy-preserving data synthesis. *arXiv preprint arXiv:1708.07975*, 2017. URL <https://arxiv.org/abs/1708.07975>. Acessado em: 29 Mar. 2024.